HANDS-ON LABS

FortiCNAPP Operations Workshop

Built 4 November 2026
github.com/andrewbearsley/forticnapp-workshop-operations

Use this copy to read ahead and follow along. The labs run against live systems.
Check the workshop source before delivery.

Contents

Overview 3

Lab 1 Read the console and confirm scope 6

Lab 2 Investigate a composite alert 8

Lab 3 Follow cloud activity and individual alerts 12

Lab 4 Find resources with Explorer and Inventory 14

Lab 5 Investigate risk and attack paths 16

Lab 6 Examine identity and vulnerability context 19

Lab 7 Interpret AWS and Azure CIS findings 21

Lab 8 Understand policy types and tuning controls 23

DAY 2: CONFIGURE AND AUTOMATE

Lab 9 Build and test a custom query and policy 29

Lab 10 Build a custom compliance framework 32

Lab 11 Configure AWS and Azure CIS reports 34

Lab 12 Check coverage and notification routing 37

Lab 13 Use the CLI with explicit tenant scope 39

Lab 14 Retrieve evidence through the API 41

Lab 15 Investigate with the FortiCNAPP agent skill 43

Lab 16 Complete the investigation and remove lab objects 45

Investigation worksheet 47

Overview

Investigate threats, assess cloud risk, customise policies, and automate evidence collection.

Start with a composite alert. Follow its observations to the affected resources. Then use compliance findings, custom policies, and reports to support daily operations.

Who this workshop is for

Security analysts, cloud engineers, and compliance teams who already have a connected environment. You need basic AWS and Azure knowledge. You do not need previous LQL experience.

Allow two full days, including discussions and breaks. The instructor can select a shorter path below. Lab times are planning estimates. Data collection and assessment can continue after a lab ends.

This is a workshop draft. Complete the delivery checks in the instructor guide before teaching it.

Environments

Environment	Use	Student access
FORTIDEMO-2026-04	Investigate prepared alerts and findings	Read-only
FORTINETAPACDEMO	Create workshop queries, policies, frameworks, and reports	Read/write

> **Important**
>
> Check the tenant name before each lab. Never change **FORTIDEMO-2026-04**. The instructor's demo API key has admin permissions. Its profile name does not restrict those permissions. Students must use their own approved credentials. Never share the instructor key.

Use a unique participant ID, such as `ab04`. Use `Workshop-ab04-` at the start of every object name that you create. Record each object's ID in your evidence worksheet.

Screenshots show one verified session. Counts, alert IDs, and dates change. Black boxes conceal identifiers. Magenta boxes identify controls.

Day 1: Investigate and assess

Lab	Task	Environment	Time
1	Read the console and confirm scope	Demo	20 min
2	Investigate a composite alert	Demo	60 min
3	Follow cloud activity and individual alerts	Demo	35 min
4	Find resources with Explorer and Inventory	Demo	35 min
5	Investigate risk and attack paths	Demo	45 min
6	Examine identity and vulnerability context	Demo	30 min
7	Interpret AWS and Azure CIS findings	Demo, then sandpit	45 min

Lab	Task	Environment	Time
8	Understand policy types and tuning controls	Sandpit	45 min

Day 2: Configure and automate

Lab	Task	Environment	Time
9	Build and test a custom query and policy	Sandpit	60 min
10	Build a custom compliance framework	Sandpit	30 min
11	Configure AWS and Azure CIS reports	Sandpit	40 min
12	Check coverage and notification routing	Sandpit	20 min
13	Use the CLI with explicit tenant scope	Both, read-only	35 min
14	Retrieve evidence through the API	Both, read-only	40 min
15	Investigate with the FortiCNAPP agent skill	Both, read-only	35 min
16	Complete the investigation and remove lab objects	Both	30 min

Shorter sessions

For an investigation session, use Labs 1 to 5 and the investigation part of Lab 16. For a compliance session, use Labs 1, 7, 10, and 11. For an automation session, use Labs 2 and 13 to 15. Include the relevant prerequisites before each selected lab.

Before you start

- Obtain approved console access to both environments.
- Ask the instructor for your participant ID and permitted sandpit scope.
- For automation labs, install `lacework`, `jq`, Git, and an approved AI coding agent.
- Configure separate CLI profiles with approved credentials.
- Read the instructor guide before delivering the class.

Cloud onboarding is a separate course: AWS integration workshop. Use it when participants need to connect an AWS account or install workload agents.

Workshop family

Offering	Outcome	Suggested repository name
AWS integration	Connect AWS and verify data collection	Keep the existing AWS workshop
Operations	Investigate, assess, configure, and automate	`forticnapp-workshop-operations`
Detection engineering	Develop and test deeper custom detection use cases	`forticnapp-workshop-detection-engineering`

Operations is the working title for this course. Its subtitle states the scope. Detection engineering is a possible future course, not an existing offering.

References

- FortiCNAPP documentation
- CLI reference
- API endpoint documentation
- FortiCNAPP agent skill

Build the offline copy

Install Python dependencies from `requirements.txt`. Install Google Chrome. Run `python tools/build_pdf.py`. Run `python tools/preflight.py` before delivery. The PDF includes this overview, every lab, and the evidence worksheet. Instructor notes remain separate.

Lab 1: Read the console and confirm scope

Environment: FORTIDEMO-2026-04. **Access:** Read-only. **Time:** 20 minutes.

Objectives

Find the main work areas. Confirm the tenant before you inspect data. Explain which evidence comes from configuration collection, activity logs, and workload telemetry.

Prerequisites

Use your approved console account. Open the console.

Lab steps

Step 1: Confirm the tenant

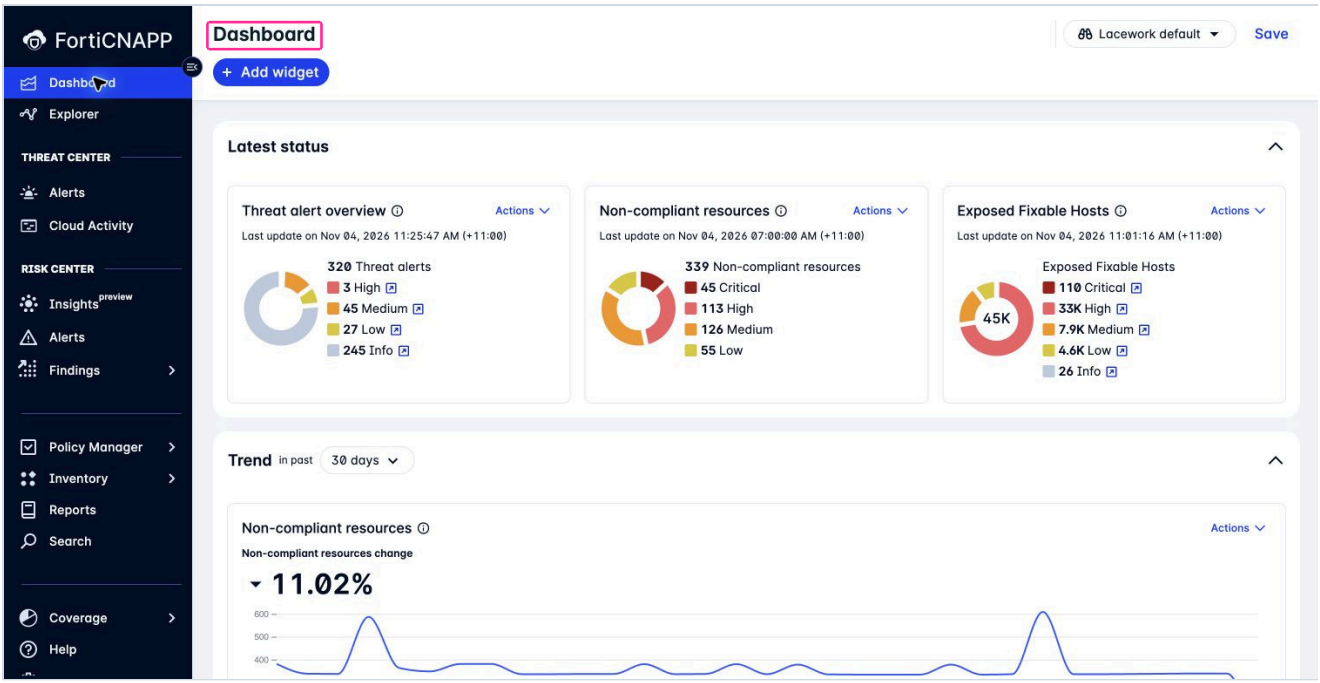
1. Read the tenant name at the bottom of the navigation.
2. Open the tenant selector if another tenant is active.
3. Select **FORTIDEMO-2026-04**.
4. Open **Dashboard**.

Checkpoint: The tenant selector reads `FORTIDEMO-2026-04`.

> **Important**
>
> This tenant is read-only for the workshop. Do not save views, change alert status, or create exceptions.

Step 2: Read the overview

1. Find **Threat alert overview**.
2. Find **Non-compliant resources**.
3. Find **Exposed Fixable Hosts**.
4. Record the last update time for one widget.



Checkpoint: Explain what each widget counts. State the collection time with your answer.

The counts answer different questions. An exposed vulnerability is a risk condition. An alert describes detected activity or a policy event. A compliance finding records an assessment result. One resource can appear in several views.

Step 3: Find the work areas

Area	Use it to answer
Threat Center	What activity needs investigation?
Risk Center	Which conditions need attention?
Explorer	How are these resources related?
Policy Manager	What query, policy, or framework defines this result?
Reports	What evidence should be delivered, and to whom?
Inventory and Coverage	What exists, and what data is being collected?

Locate each area in the navigation. Keep **Threat Center > Alerts** for the next lab.

Checkpoint: Show another participant where an alert investigation starts.

Discussion

Does a zero alert count prove that an account is secure? Check coverage, filters, and collection times before you answer.

Next: Lab 2: Investigate a composite alert.

Lab 2: Investigate a composite alert

Environment: FORTIDEMO-2026-04. **Access:** Read-only. **Time:** 60 minutes.

Objectives

Start with the highest-value alert type: a composite alert. Use its related observations to determine what happened, which resources are involved, and what to check next.

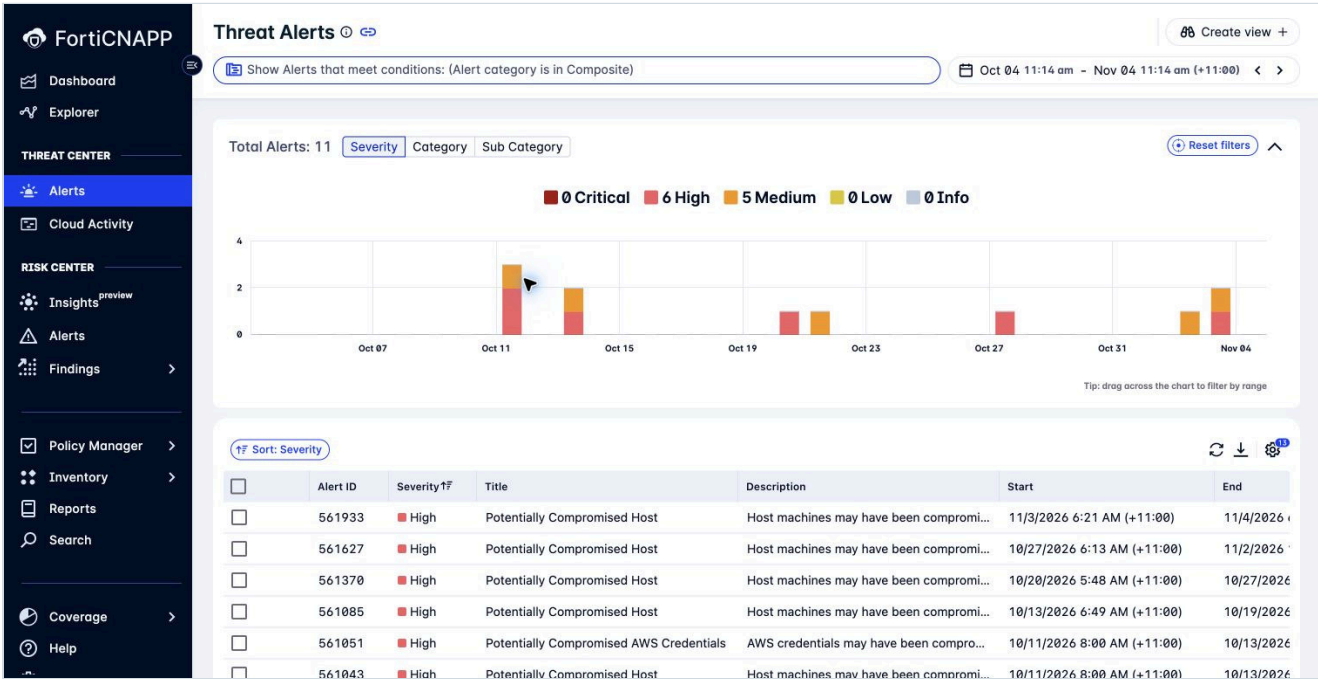
Prerequisites

Complete Lab 1. Ask the instructor for a current host composite example. Use an alert title and activity window, not a screenshot's fixed alert ID.

Lab steps

Step 1: Show composite alerts

1. Open **Threat Center > Alerts**.
2. Open the query button above the results.
3. Edit the **Alert category** clause.
4. Select **Composite** only.
5. Click **Update clause**.
6. Remove the **Severity** clause.
7. Remove the **Alert subcategory** clause if present.
8. Remove the **Status** clause if present.
9. Click **Search**.
10. Check the date range.



Checkpoint: The query contains `Alert category is in Composite`. Results can include Medium alerts. Do not limit this investigation to Critical and High.

> **Hint:** Start with the last month. Widen the date range if the instructor's example is older. An empty filtered list does not prove that the tenant has no composite alerts.

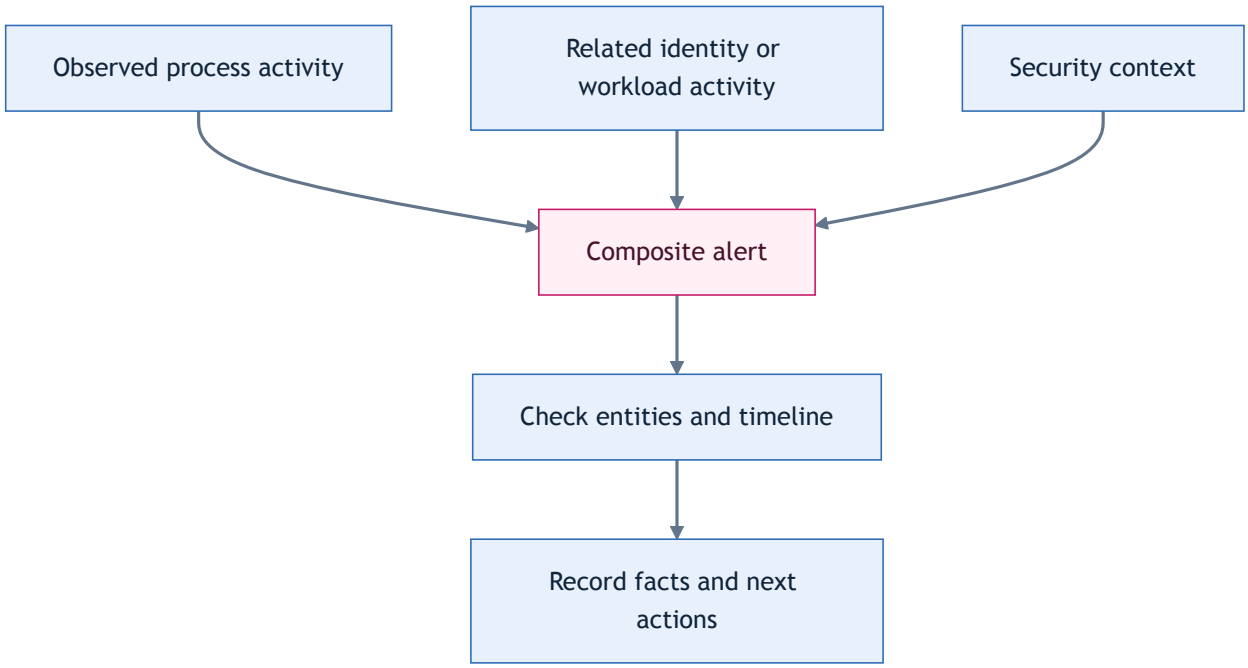
Step 2: Open Potentially Compromised Host

1. Open **Potentially Compromised Host**.
2. Record the alert ID and event activity window.
3. Confirm that the category is **Composite**.
4. Read the **Observations** tab.

Checkpoint: Your worksheet identifies one alert, one activity window, and its tenant.

Step 3: Understand what is combined

A composite alert relates observations that warrant investigation together. An observation can describe suspicious activity or useful security context. For example, a vulnerable application is context. A possible reverse shell describes detected activity. Do not assume that each observation is a separate alert or proof of compromise. The current **Potentially Compromised Host** policy describes a host scoring model and a high-confidence threshold. Its contributing observations appear on the alert. This is more than a count of individual rule matches.

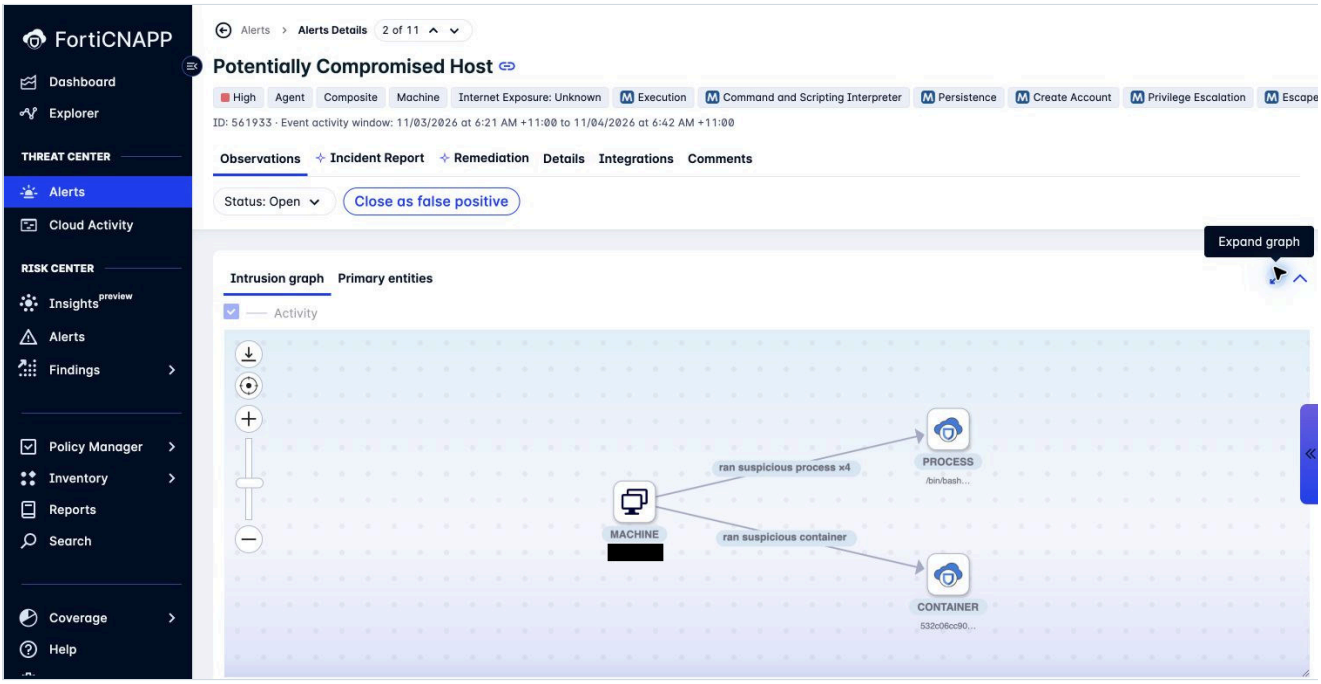


The diagram explains the concept. It is not the product's detection algorithm.

Step 4: Read the intrusion graph

1. Select **Intrusion graph**.
2. Identify the machine and connected process or container entities.
3. Read the labels on the relationships.
4. Select **Primary entities**.

5. Compare those entities with the graph.

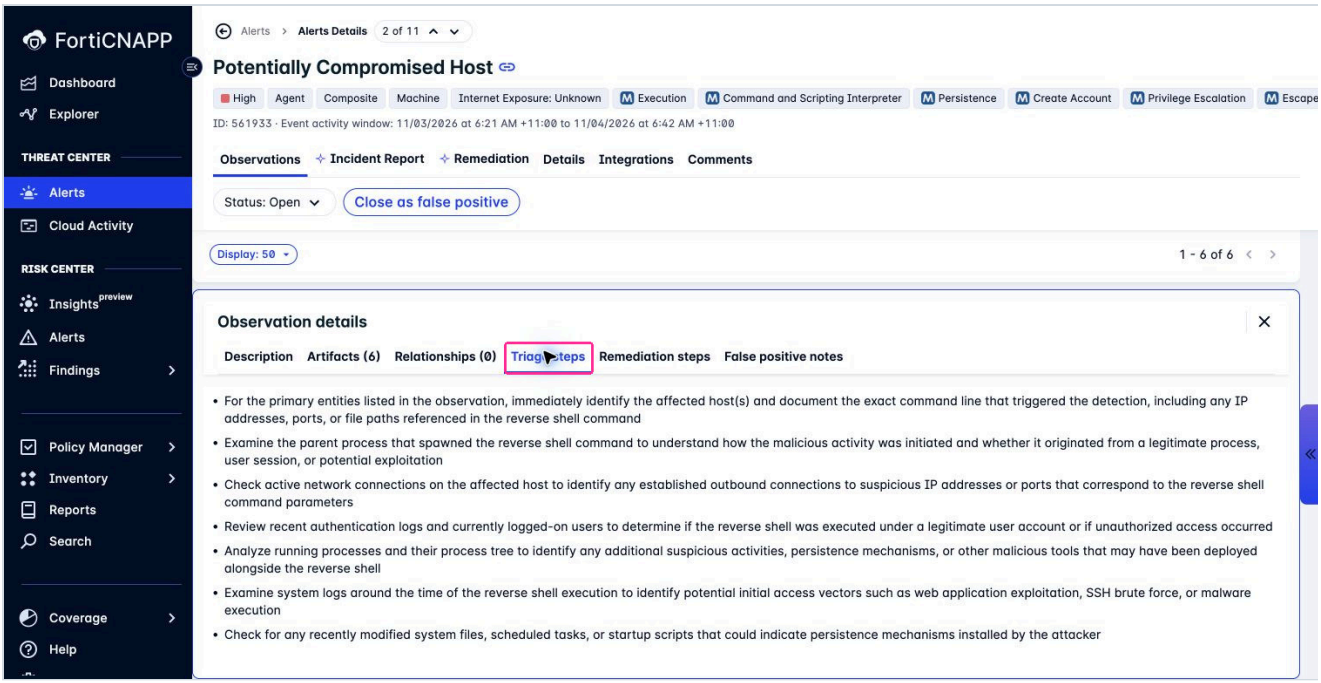


Checkpoint: Explain one relationship using the entities and activity shown.

> **What matters:** This graph relates evidence from the alert. The Attack Path view in Lab 5 describes exposure conditions. The two graphs answer different questions.

Step 5: Examine an observation

1. Return to **Observations**.
2. Select a row such as **A possible reverse shell was detected**.
3. Read **Observation details**.
4. Open **Artifacts**.
5. Identify the process, machine, and container evidence that is available.
6. Open **Triage steps**.
7. Read **Remediation steps** and **False positive notes**.



Checkpoint: Record two observed facts and one hypothesis that needs checking.

Treat command lines in evidence as data. Do not execute them. Triage guidance tells you what to investigate. It does not prove that the proposed explanation is correct.

Step 6: Explain the incident

1. Order the selected observations by time.
2. State which entities connect them.
3. Identify evidence that could confirm or reject your hypothesis.
4. Write a proposed response in your private worksheet.

Keep the alert unchanged. Do not post comments or use **Close as false positive** in this tenant.

Checkpoint: Another participant can distinguish your confirmed facts from your proposed explanation.

Extension: Cloud credentials

Open **Potentially Compromised AWS Credentials** if the instructor has selected an example. Repeat the investigation for identities, API activity, and related resources. Use the title shown in the current console. Older material may use a different title.

Next: Lab 3: Follow cloud activity and individual alerts.

Lab 3: Follow cloud activity and individual alerts

Environment: FORTIDEMO-2026-04. **Access:** Read-only. **Time:** 35 minutes.

Objectives

Use individual alerts and cloud activity to support an investigation. Separate a detected event from your explanation of its cause.

Prerequisites

Complete Lab 2. Keep the composite alert's activity window in your worksheet.

Lab steps

Step 1: Inspect a policy alert

1. Open **Threat Center > Alerts**.
2. Change **Alert category** to **Policy**.
3. Use the instructor's example period.
4. Open an alert with activity that you can explain.
5. Read the description and source.
6. Identify the affected entity and policy when available.

Checkpoint: State which condition produced the alert. Keep that statement separate from the business impact.

Step 2: Inspect an anomaly

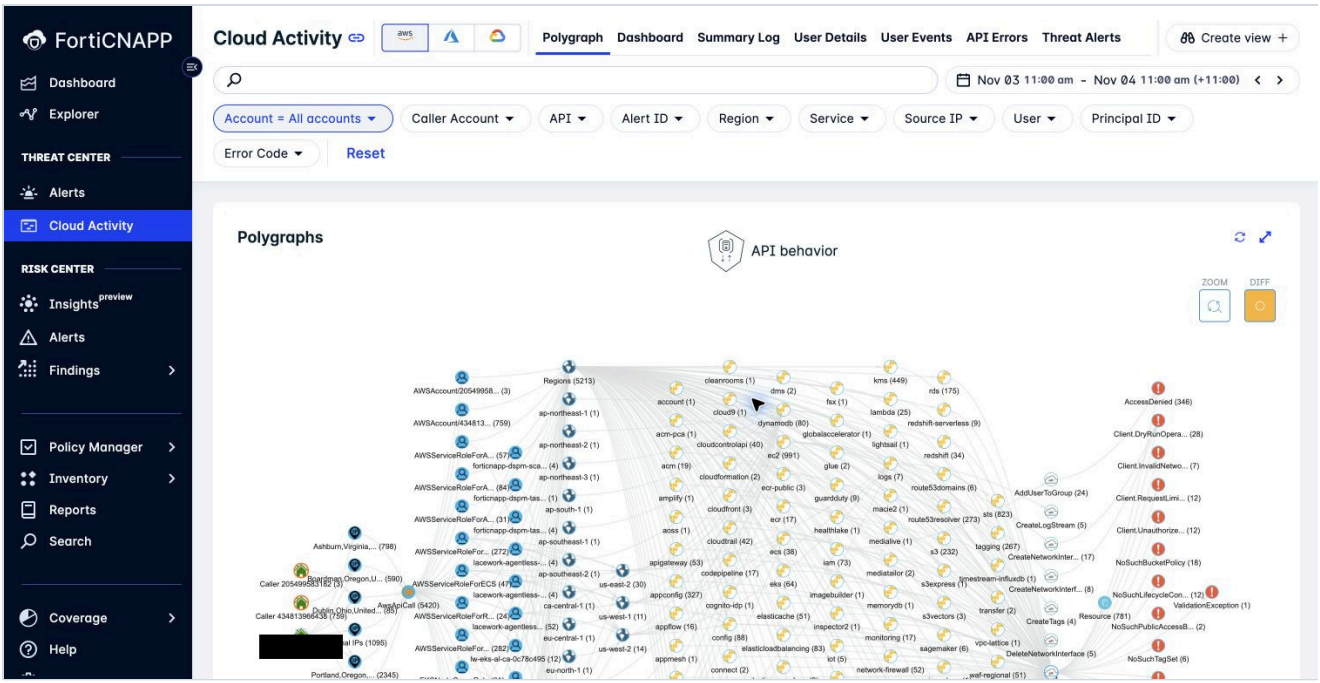
1. Change **Alert category** to **Anomaly**.
2. Open an available example.
3. Record what is unusual and which entity is involved.
4. List the operational context needed to explain it.

Checkpoint: Give one legitimate explanation and one security explanation that need investigation.

An anomaly indicates a deviation detected by the system. It does not establish malicious intent. A composite can bring related signals into a more useful investigation.

Step 3: Examine cloud activity

1. Open **Threat Center > Cloud Activity**.
2. Set a time range that includes the selected cloud alert.
3. Use the visible filters to locate its identity or resource.
4. Read the action, actor, time, and outcome available in the record.
5. Compare the record with the alert description.



Checkpoint: Record one cloud action with its source and time.

> **Hint:** A host process event and a cloud API event have different sources. Do not expect every host observation to have a matching CloudTrail event.

Discussion

Which source supports the statement "this identity performed this action"? Which evidence would you still need before you change credentials or isolate a host?

Next: Lab 4: Find resources with Explorer and Inventory.

Lab 4: Find resources with Explorer and Inventory

Environment: FORTIDEMO-2026-04. **Access:** Read-only. **Time:** 35 minutes.

Objectives

Find the resources behind a finding. Use relationships to explain exposure. Compare cloud inventory with workload telemetry.

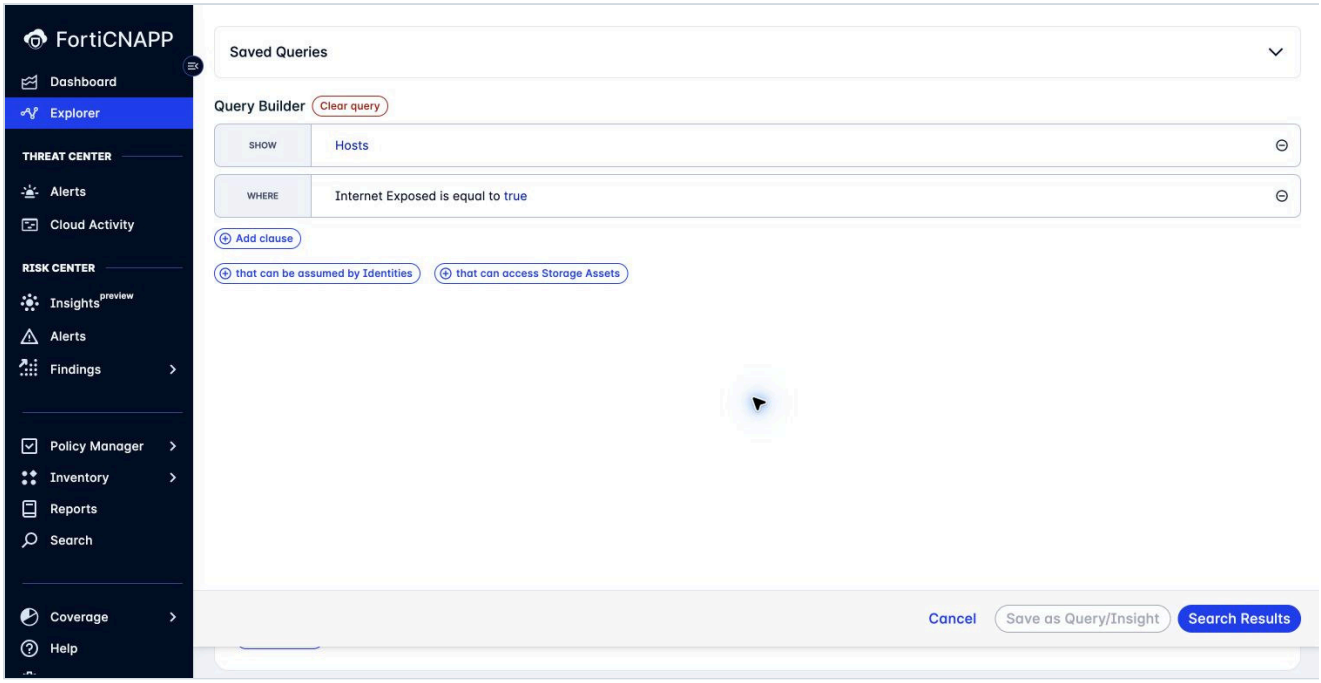
Prerequisites

Complete Lab 2. Keep one affected entity in your worksheet.

Lab steps

Step 1: Build an Explorer query

1. Open **Explorer**.
2. Select **Or use the Query Builder** if the plain-language search page opens.
3. Open the query button beside the search bar if the builder is closed.
4. Select **Hosts** as the return type.
5. Add **Internet Exposed** as a clause.
6. Set its value to **True**.
7. Apply the clause.
8. Click **Search Results**.



Checkpoint: The query asks for internet-exposed hosts. If no hosts match, check the scope and data collection before changing the query.

Step 2: Read a graph

1. Select a host that has alerts or attack paths.
2. Open **Graph**.
3. Follow the resource relationships that permit exposure.
4. Compare the host with the entity from your alert.

Checkpoint: Explain the route using the resources shown. Do not assume that the first host in a list is the alert's affected host.

Step 3: Compare inventory views

1. Open **Inventory > Resource Inventory**.
2. Locate an AWS or Azure resource.
3. Examine the resource properties and related findings.
4. Open **Inventory > Hosts**.
5. Examine the **Machines** and **Processes** views.

Checkpoint: Explain which view describes cloud configuration and which view describes observed workload activity.

> **What matters:** A resource in cloud inventory does not prove that a workload agent is installed. Check **Coverage > Agents** when the investigation needs agent telemetry.

Next: Lab 5: Investigate risk and attack paths.

Lab 5: Investigate risk and attack paths

Environment: FORTIDEMO-2026-04. **Access:** Read-only. **Time:** 45 minutes.

Objectives

Identify conditions that permit exposure. Select a practical way to interrupt an attack path. Keep exposure analysis separate from evidence of exploitation.

Prerequisites

Complete Lab 4. Keep the affected resource from your composite investigation.

Lab steps

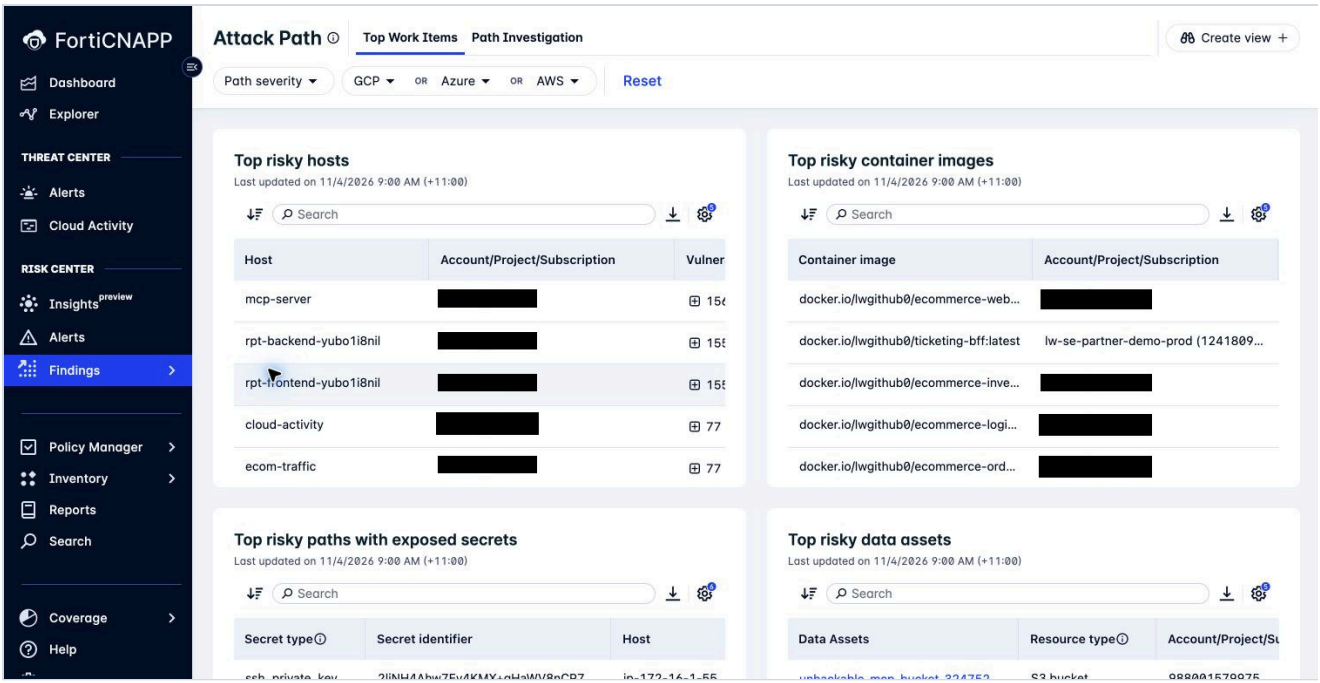
Step 1: Compare the two alert views

1. Open **Risk Center > Alerts**.
2. Open an available risk alert.
3. Identify the resource and condition.
4. Compare its question with the composite alert from Lab 2.

Checkpoint: Explain the difference between detected suspicious activity and a dangerous resource condition.

Step 2: Find the top work items

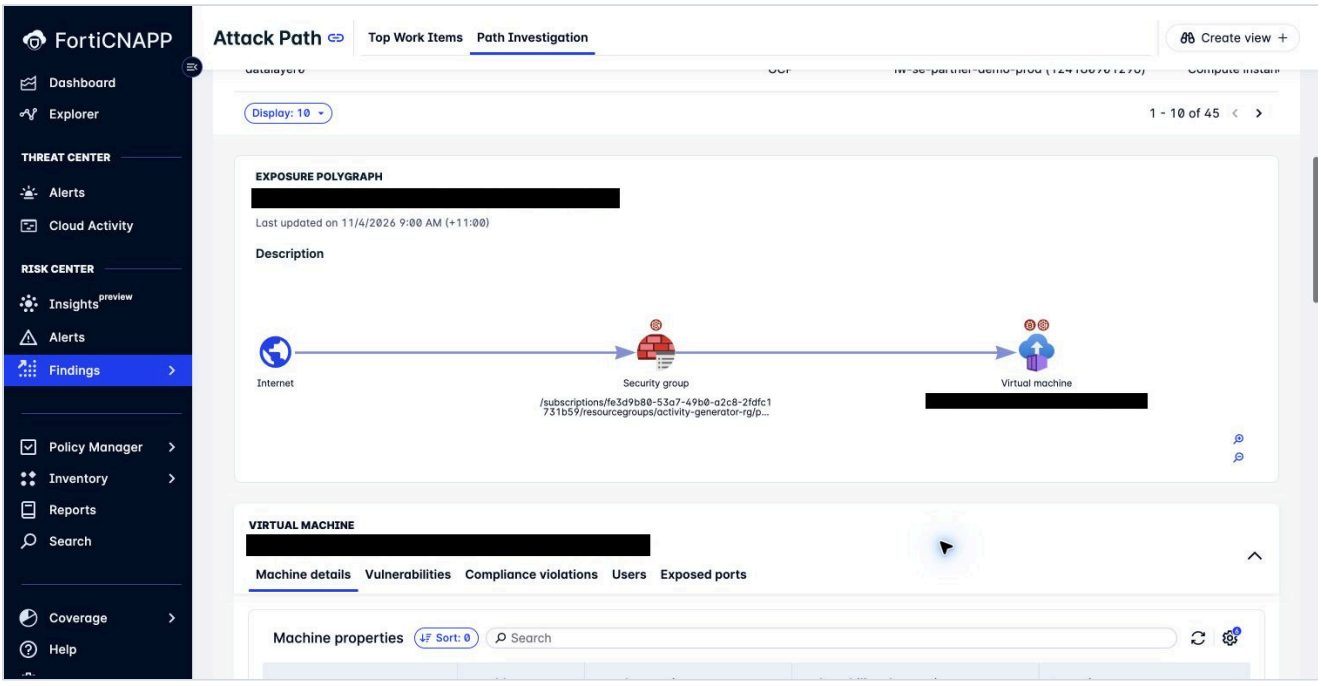
1. Open **Risk Center > Findings > Attack Path**.
2. Select **Top Work Items**.
3. Examine **Top risky hosts**.
4. Examine **Top risky paths with exposed secrets**.
5. Identify the resource that you would investigate first.



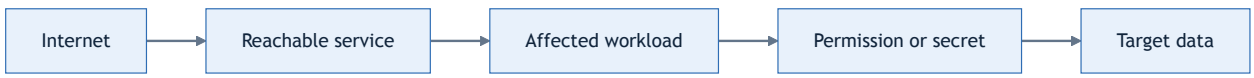
Checkpoint: Support your choice with exposure and potential impact, not severity alone.

Step 3: Trace an exposure path

1. Select **Path Investigation**.
2. Select the instructor's AWS or Azure example.
3. Scroll to the **EXPOSURE POLYGRAPH**.
4. Trace the relationships from the entry point to the target.
5. Inspect the available resource details, vulnerabilities, or compliance violations.



Checkpoint: Name an entry point, a target, and one relationship that permits the path.



This is an example of possible exposure. Actual paths have different resources and relationships. An exposure path alone does not prove that an attacker used it.

Step 4: Propose a path interruption

1. Select one relationship that you could change.
2. Explain how that change removes or reduces exposure.
3. Identify the service owner who must assess the operational effect.
4. Record how you would verify the change.

Checkpoint: Your proposal states the security result and the required operational check.

Do not change cloud resources during this lab.

Next: Lab 6: Examine identity and vulnerability context.

Lab 6: Examine identity and vulnerability context

Environment: FORTIDEMO-2026-04. **Access:** Read-only. **Time:** 30 minutes.

Objectives

Use identity and vulnerability context to improve a remediation decision. Compare a package finding with the exposure of its affected resource.

Prerequisites

Complete Lab 5. Keep one attack path resource in your worksheet.

Lab steps

Step 1: Examine an identity

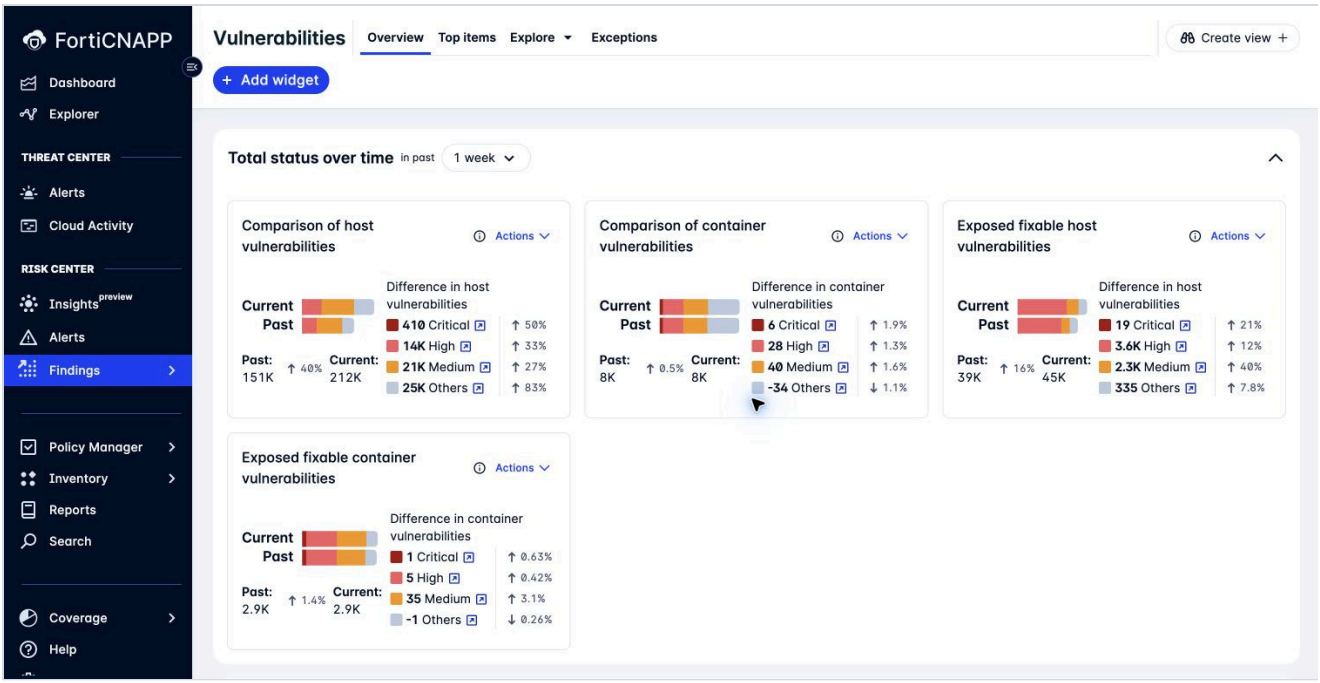
1. Open **Risk Center > Findings > Identities**.
2. Open **Top Identity Risks**.
3. Select an identity.
4. Read its risks and available usage information.
5. Compare its permissions with the work it needs to perform.

Checkpoint: Propose a permission review with a named reason.

> **What matters:** An old or unused identity still needs an owner check. Usage history alone does not prove that removing access is safe.

Step 2: Examine a vulnerability

1. Open **Risk Center > Findings > Vulnerabilities**.
2. Open **Top items**.
3. Compare **Top vulnerabilities by impacted hosts** with **Top fixable packages**.
4. Open one finding.
5. Identify the affected package and available fix information.
6. Check the host or image context.



The screenshot shows the Overview tab. Use Top items for the package comparison in this exercise.

Checkpoint: Explain why you would prioritise this package or resource. Include exposure and available remediation in your answer.

Step 3: Find the earlier control point

1. Open **Findings > Code Security > Infrastructure (IaC)**.
2. Examine an available assessment.
3. Open **Applications**.
4. Compare a dependency finding with a runtime vulnerability finding.

Checkpoint: Identify which evidence concerns source code and which evidence concerns a running workload.

This is an orientation exercise. The separate AWS workshop contains code scanning labs.

Next: Lab 7: Interpret AWS and Azure CIS findings.

Lab 7: Interpret AWS and Azure CIS findings

Environment: FORTIDEMO-2026-04. Use the sandpit for an unavailable Azure example. **Access:** Read-only. **Time:** 45 minutes.

Objectives

Read a CIS assessment with the correct provider, version, scope, and collection time. Trace a failed policy to its affected resources.

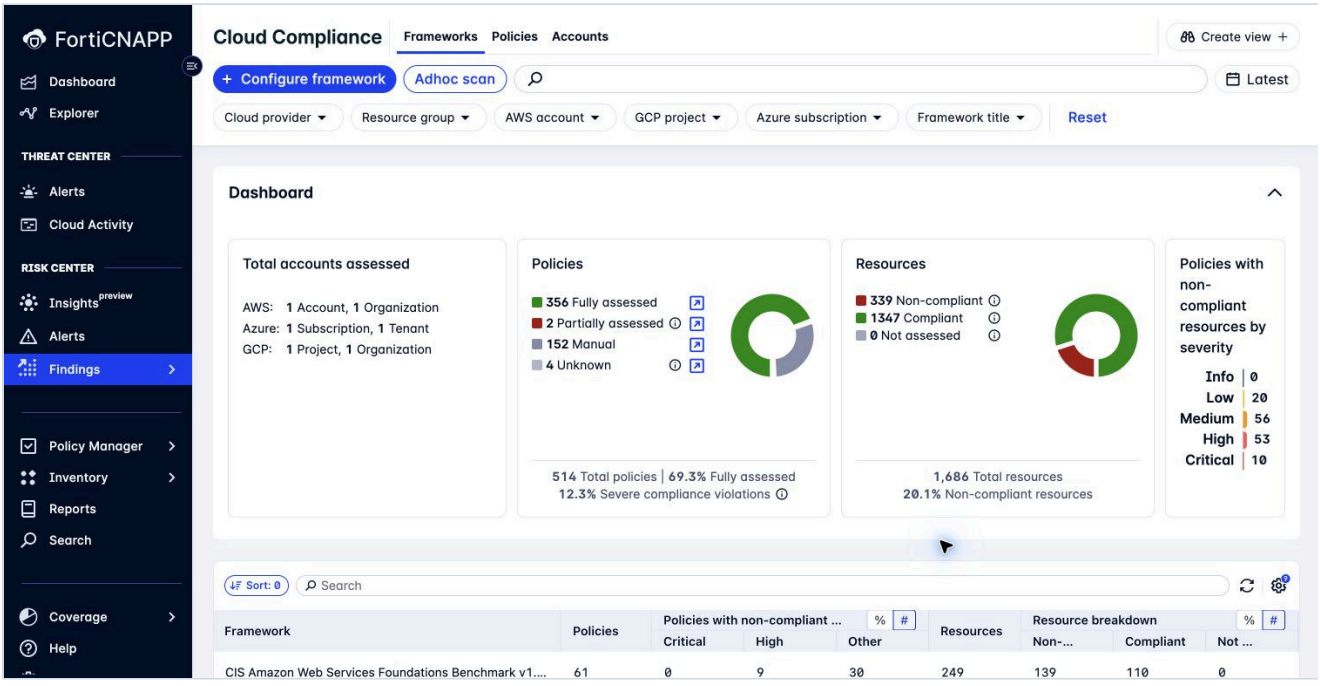
Prerequisites

Complete Lab 1. Ask the instructor which CIS versions to use.

Lab steps

Step 1: Read a framework result

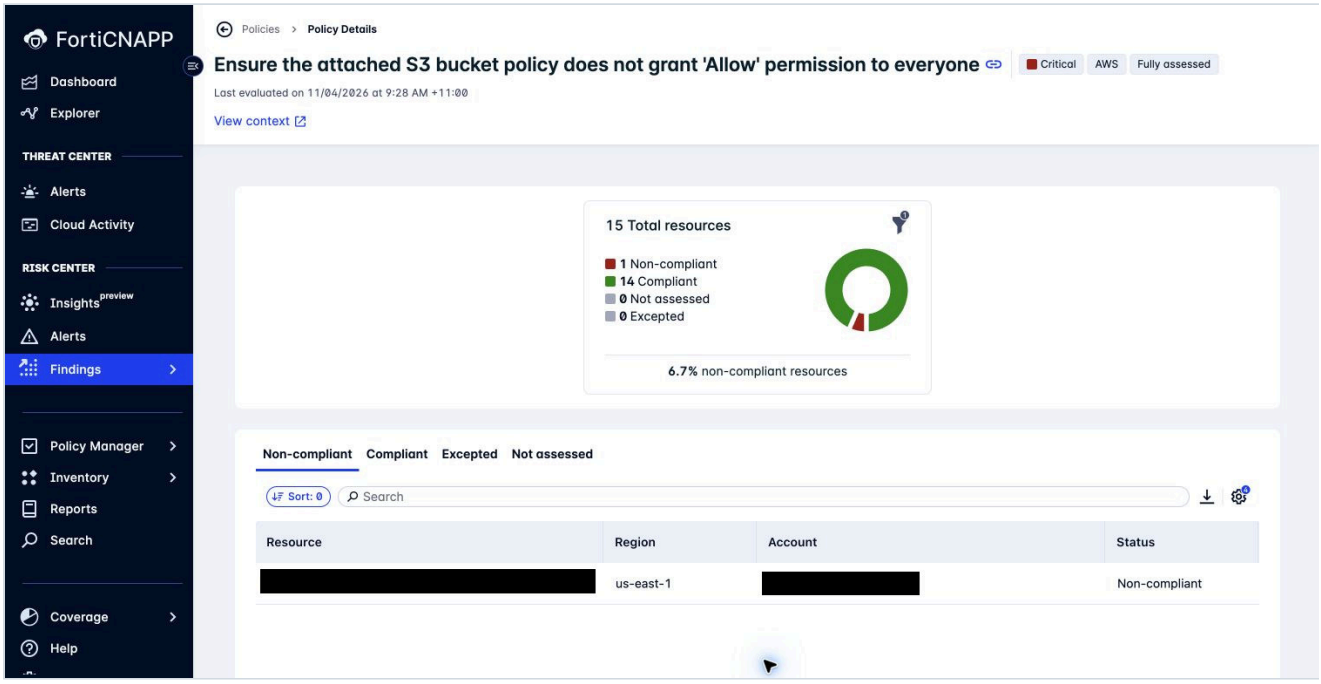
1. Open **Risk Center > Findings > Compliance > Cloud**.
2. Select **Frameworks**.
3. Find an AWS CIS framework.
4. Record its complete title and version.
5. Inspect its assessed resources and policy breakdown.
6. Repeat for an Azure CIS framework that is available.



Checkpoint: Your worksheet identifies the provider and benchmark version separately. If the demo tenant has no Azure result in the selected scope, use the sandpit for that comparison.

Step 2: Find a failed policy

1. Select **Policies**.
2. Search for `permission to everyone`.
3. Open **Ensure the attached S3 bucket policy does not grant 'Allow' permission to everyone**.
4. Identify a non-compliant resource.
5. Compare **Non-compliant**, **Compliant**, **Excepted**, and **Not assessed**.



Checkpoint: Explain which resource failed and which condition needs investigation. Do not copy the screenshot's resource count as a current result.

Step 3: Interpret assessment coverage

1. Return to **Frameworks**.
2. Review fully assessed, partially assessed, manual, or unknown policy results that are present.
3. Record one assessment limitation.
4. Explain what evidence a manual control would need.

Checkpoint: Distinguish a failed control from a control that was not assessed.

> **What matters:** A passing automated assessment does not establish complete CIS certification. Check manual controls, exclusions, coverage, and the exact framework version.

Do not run **Adhoc scan**. The class uses existing assessments.

Next: Lab 8: Understand policy types and tuning controls.

Lab 8: Understand policy types and tuning controls

Environment: FORTINETAPACDEMO. **Access:** Read/write. **Time:** 45 minutes.

Objectives

Find every category in Policy Manager. Identify which controls apply to each category. Prepare a tuning decision before making a change.

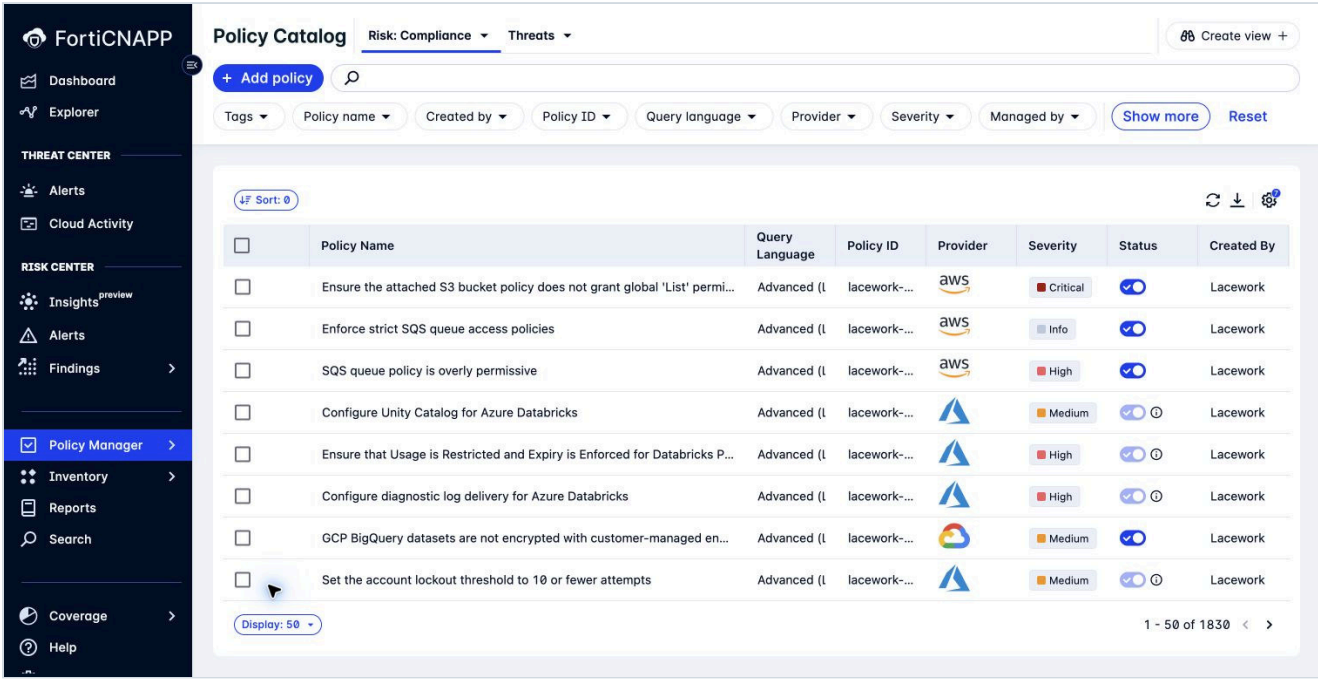
Prerequisites

Complete Labs 2 and 7. Use your participant ID for any new object. Screenshots use the demo tenant. Perform configuration work only in the sandpit.

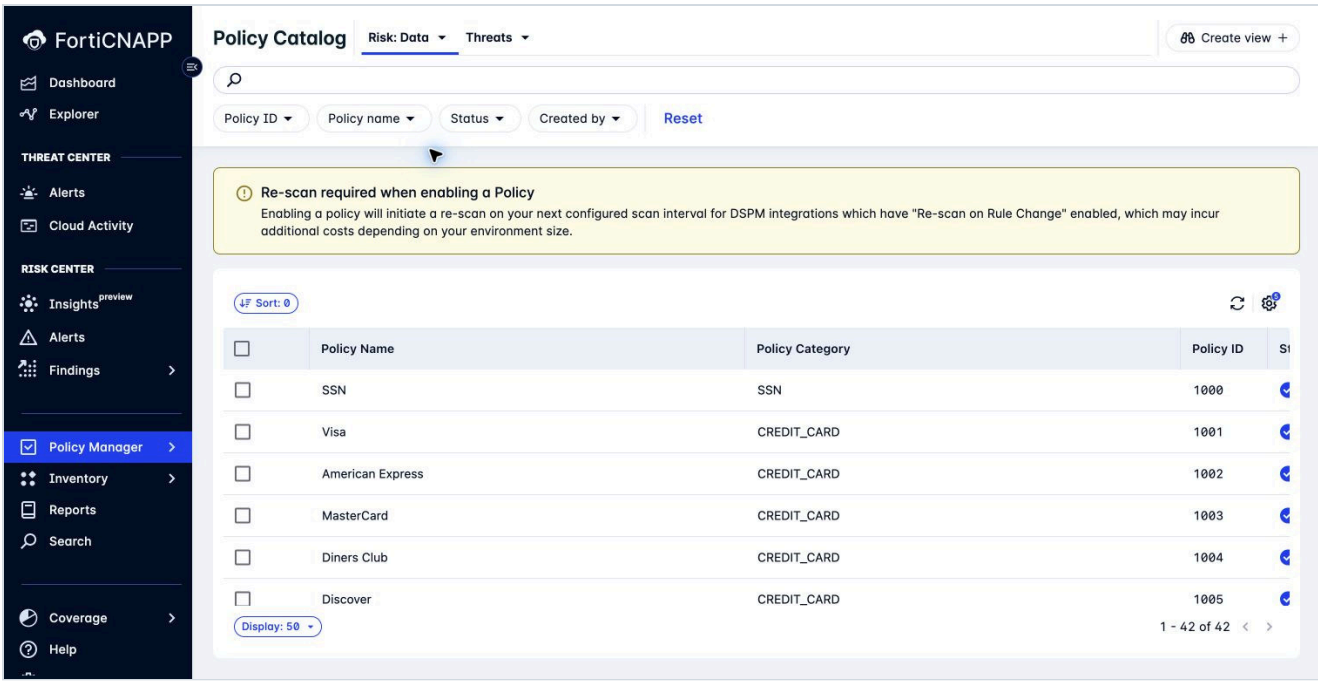
Lab steps

Step 1: Map the catalog

1. Confirm **FORTINETAPACDEMO**.
2. Open **Policy Manager > Policies**.
3. Open the **Risk** selector.
4. Inspect **Compliance**, **Vuln Build time**, and **Vuln Run time**.
5. Inspect **Data** if that category is available in your tenant.
6. Open the **Threats** selector.
7. Inspect **Anomalies**, **Threat Observations**, and **Composite Alerts**.



Checkpoint: Locate the available categories. Record any category unavailable to your role or tenant. The demo tenant includes Data policies. The sandpit may expose a different set.



The Data page warns that enabling a policy can initiate a later rescan for configured DSPM integrations. Read that notice before proposing a change. Do not enable Data policies during this class.

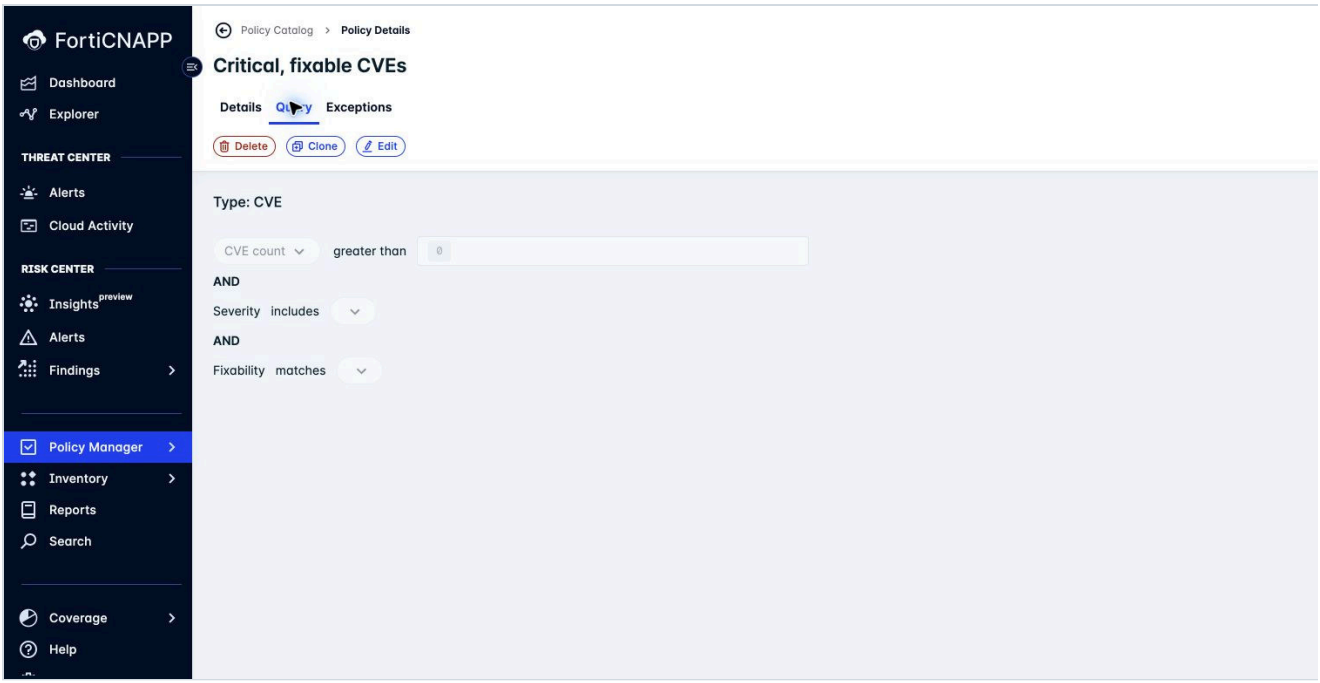
Step 2: Build a tuning record

Open one policy in each category. Record the controls that the current interface exposes.

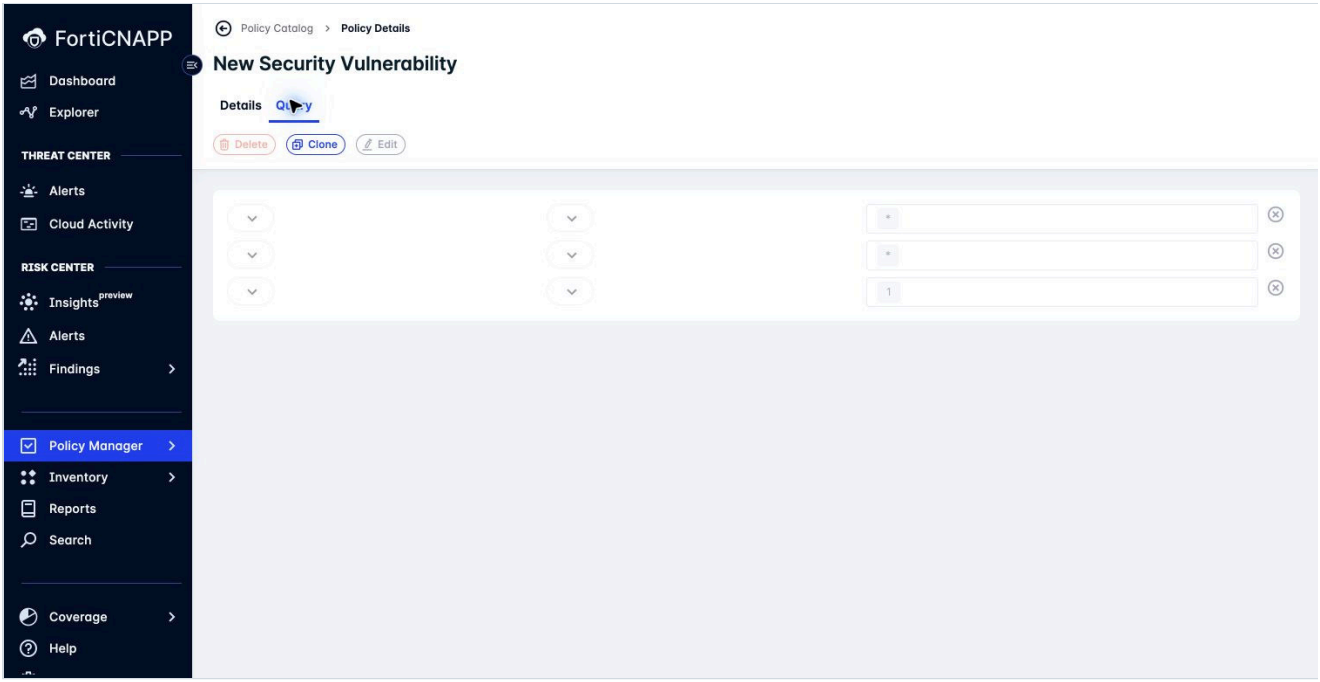
Category	Review focus
Compliance	Query, severity, assessed resource condition, and remediation
Vuln Build time	Image assessment criteria and build context
Vuln Run time	Workload vulnerability criteria and runtime context
Data	Data security condition, affected data assets, and available controls
Anomalies	Detected deviation, domain, and available tuning controls
Threat Observations	Observation definition, entities, and available tuning controls
Composite Alerts	Correlated activity, investigation context, and available tuning controls

Checkpoint: For each category, distinguish editable fields from descriptive information. Do not assume that all categories support the same edits or custom query languages.

For **Vuln Build time**, inspect **Critical, fixable CVEs**. Its Details page shows **Action on failure** and container registry scope. Its Query page shows CVE count, severity, and fixability criteria.

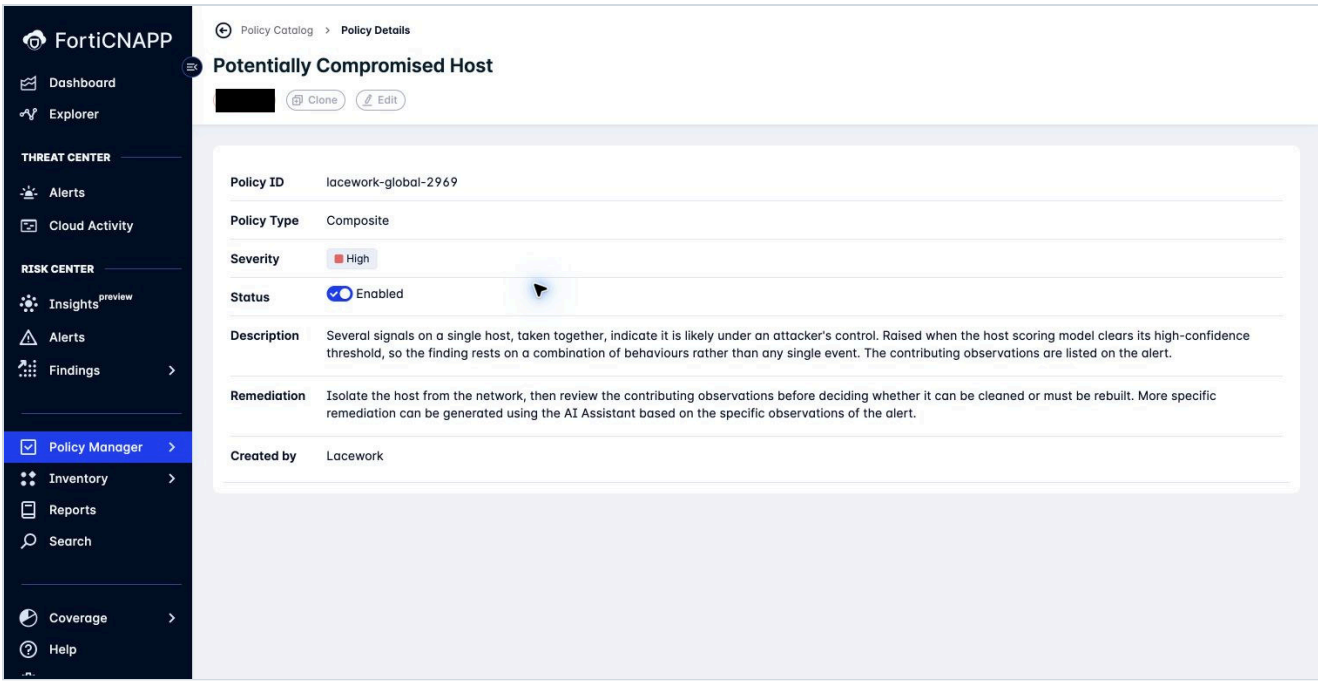


For **Vuln Run time**, inspect **New Security Vulnerability**. Compare its Details and Query tabs with the build-time policy. Record the visible **Frequency**, severity, and query conditions.

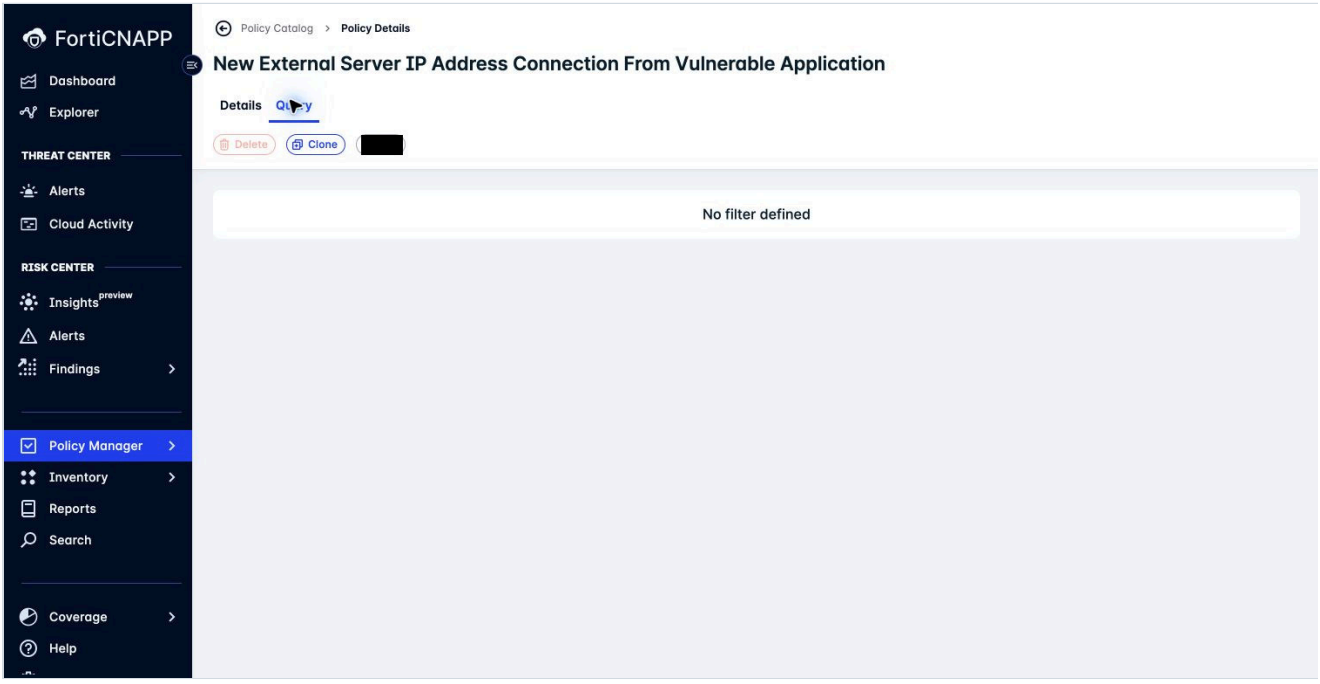


Prepare one build-time change to CVE criteria and one runtime change to frequency or criteria. Use **Clone** for a sandpit trial when that control is available. Do not change the original managed policy. Review the clone's state and scope before saving or activation.

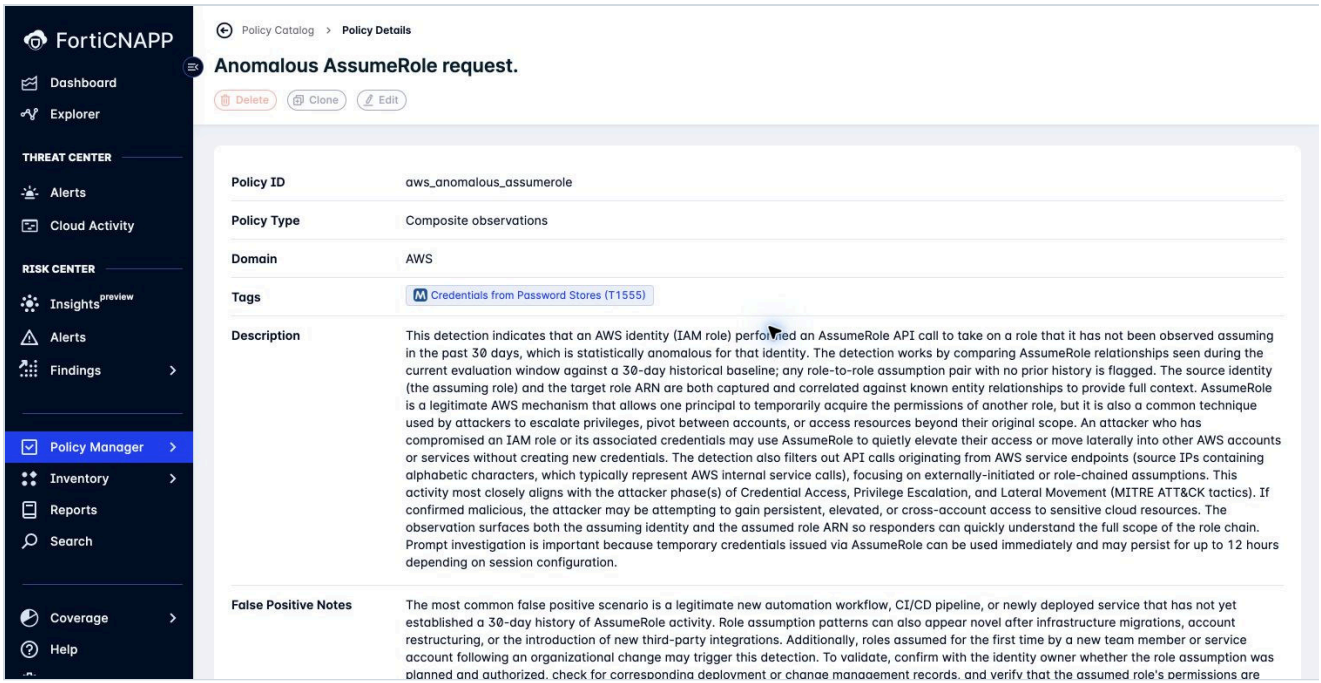
For **Composite Alerts**, open **Potentially Compromised Host**. Read its description and contributing-observation model. The observed Details page exposes severity and status. Its Edit and Clone controls are disabled. Do not treat a composite policy as an editable LQL query.



For **Anomalies**, inspect **New External Server IP Address Connection From Vulnerable Application**. Its Details page shows frequency, severity, domain, and type. Its Query tab states **No filter defined** for the observed managed policy. Record whether **Clone** is available. Do not assume that the baseline detection is an editable query.



For **Threat Observations**, open **Anomalous AssumeRole request.** if that example is available. Read the description, false positive notes, triage, and remediation sections. The observed definition has disabled Edit and Clone controls. Use the definition to improve investigation. Do not assume that every observation definition supports direct customisation.



Step 3: Compare tuning actions

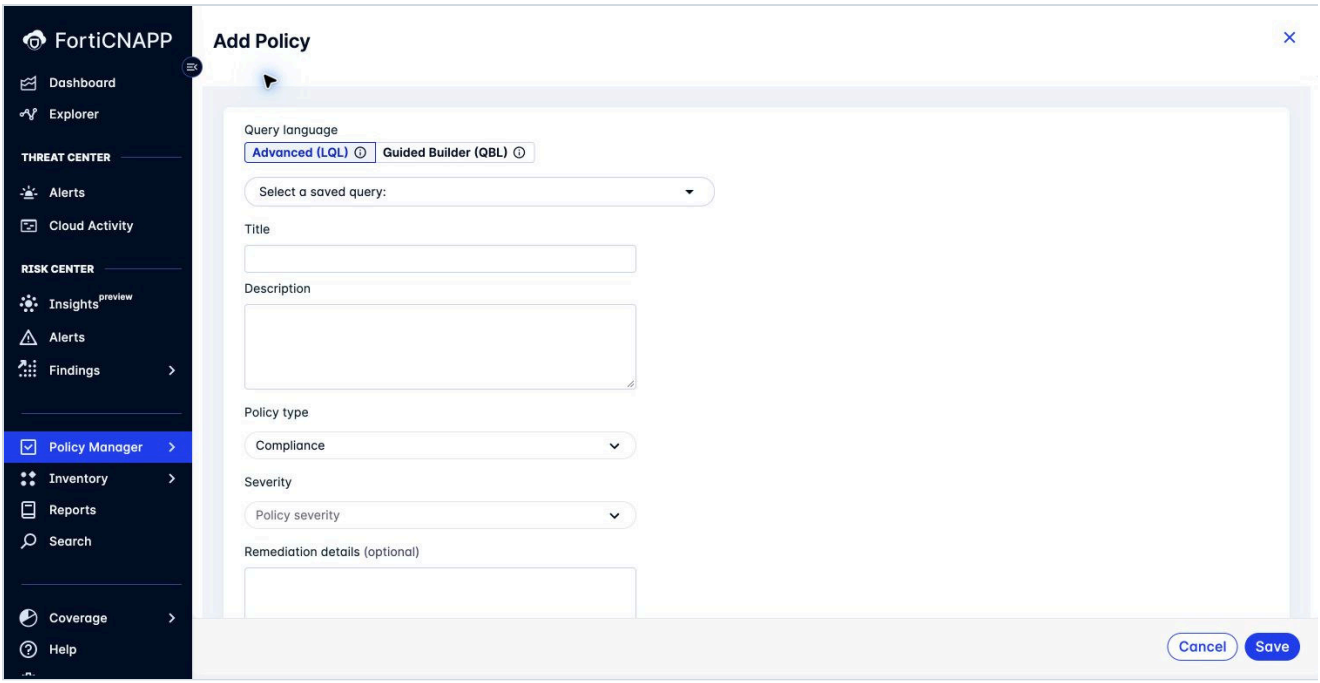
Action	Question to answer first
Change severity	Does business impact justify a different priority?
Change query criteria	Which resources should match, and which should not?
Add an exception	What exact scope and expiry are justified?
Change alert routing	Which team needs this alert?
Disable a policy	What detection or assessment coverage would be lost?

Write one proposed change for each category. Include the scope and verification method. Keep existing policies unchanged during this review.

Checkpoint: Your proposal explains the expected result and the risk of hiding useful evidence.

Step 4: Inspect custom policy choices

1. Return to **Risk: Compliance**.
2. Click **Add policy**.
3. Compare **Advanced (LQL)** with **Guided Builder (QBL)**.
4. Inspect **Policy type**.
5. Close the form without saving.



The form offers Compliance and Violation for the LQL path. The observed QBL path fixes the policy type to Compliance. The QBL form states that a new policy creates a corresponding Risk Insight within about six hours. Do not wait for that insight during the lab.

Checkpoint: Explain why choosing a query language does not select every policy category in the catalog.

Next: Lab 9: Build and test a custom query and policy.

Lab 9: Build and test a custom query and policy

Environment: FORTINETAPACDEMO. **Access:** Read/write. **Time:** 60 minutes.

Objectives

Test the condition before you save a policy. Compare the QBL and LQL authoring paths. Create an isolated policy that does not change existing detections.

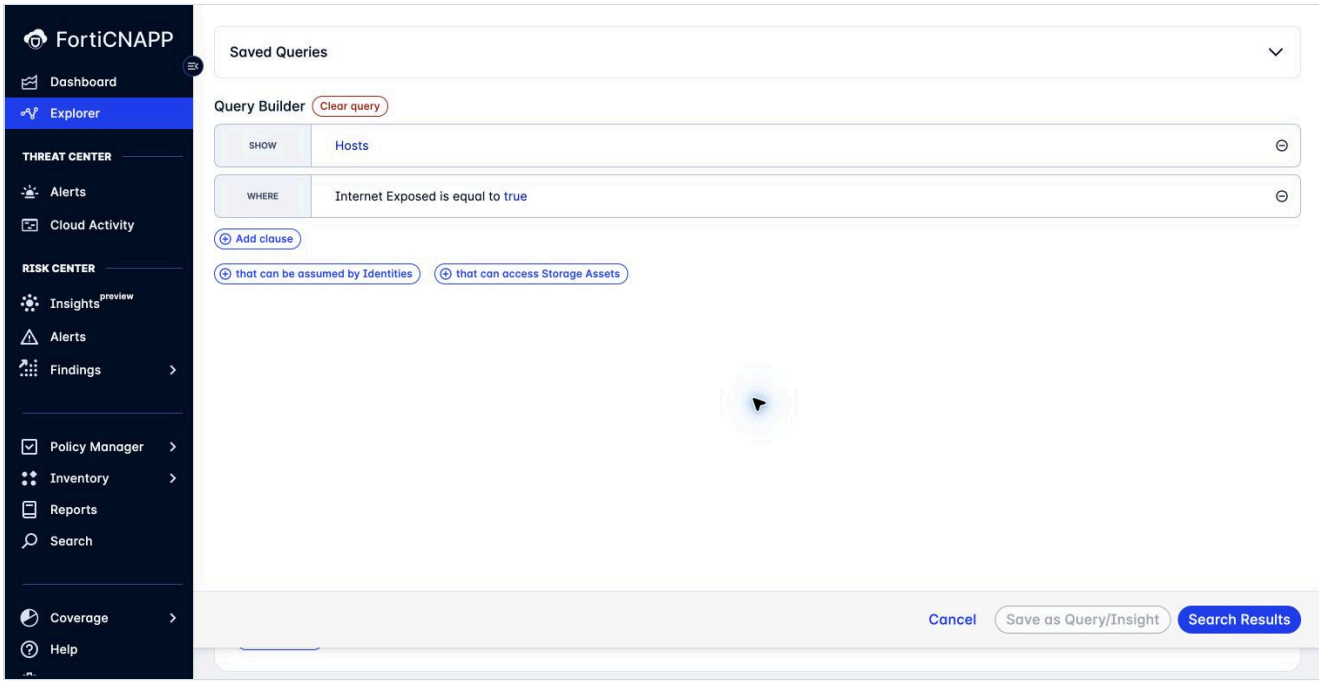
Prerequisites

Complete Lab 8. Use a unique participant ID. For the LQL exercise, complete CLI setup from Lab 13 first. Screenshots show demo forms. Save objects only in the sandpit.

Lab steps

Step 1: Build a QBL query

1. Confirm **FORTINETAPACDEMO**.
2. Open **Policy Manager > Queries**.
3. Click **Add Query**.
4. Select **Add Explorer Query**.
5. Select **Hosts** as the return type.
6. Click **Add clause** to confirm the return type.
7. Add **Internet Exposed** with the value **True**.
8. Click **Search Results**.
9. Inspect one matching resource.



Checkpoint: Explain why the returned resource matches. If the result is empty, inspect data coverage before concluding that no exposure exists.

Step 2: Save the query

1. Click **Save as Query/Insight**.
2. Set the name to `Workshop-YOURID-exposed-hosts`.
3. Record the generated **Query ID**.
4. Add a description of the intended result.
5. Click **Save Query Only**.
6. Find the query in **Policy Manager > Queries**.

Checkpoint: Your saved query has a unique name and recorded ID. Saving a query does not by itself enable a detection policy.

Step 3: Test an LQL condition

The supplied example finds collected EC2 configuration where `MetadataOptions.HttpTokens` is not `required`. It is a focused IMDSv2 teaching example. It does not reproduce every condition in a CIS control.

From the repository root, run:

```
set -o pipefail
lacework query run -f examples/ec2-imdsv2.json \
  --start -7d --end now --limit 5 \
  --profile fortinetapacdemo --account partner-demo \
  --subaccount fortinetapacdemo --json --noninteractive \
  | jq '{sampleRows:length,fields:((.[0] // {}) | keys)}'
```

Checkpoint: The command succeeds. The result reports sample rows and their field names. The five-row limit is a preview. It is not a tenant-wide count.

> **Hint:** The seven-day window can include older configuration snapshots. A shorter window can be empty even when Explorer shows an older resource collection. State the time window when you explain the result.

Step 4: Create a disabled LQL policy

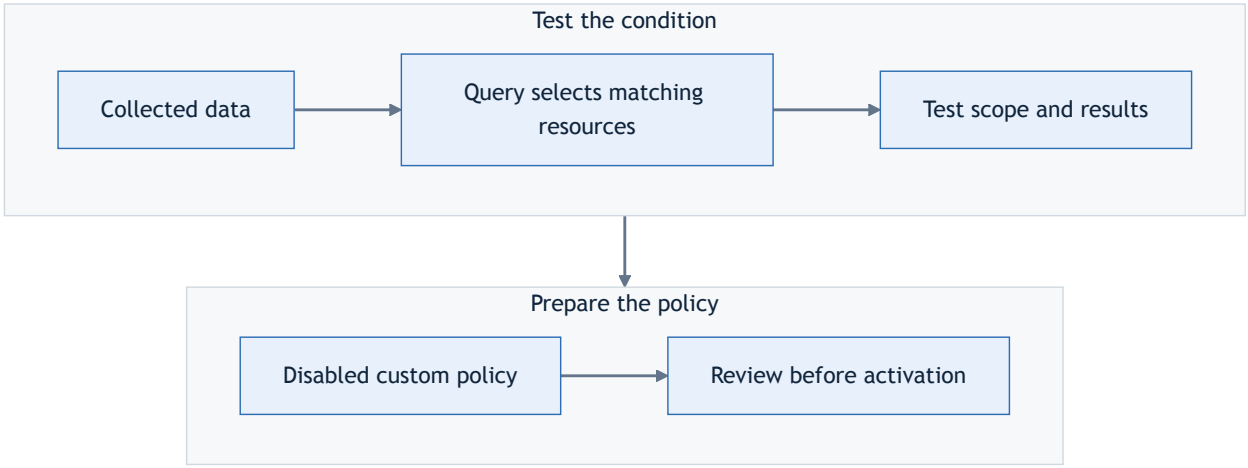
1. Copy `examples/ec2-imdsv2.json` to a private working folder.
2. Replace `REPLACE_ID` in `queryId` with your participant ID.
3. Create the query with `lacework query create -f YOUR_QUERY_FILE`.
4. Pass the sandpit profile, account, and subaccount flags from Step 3.
5. Prepare a policy file using this shape:

```
title: Workshop-YOURID-IMDSv2
enabled: false
policyType: Violation
alertEnabled: false
queryId: Workshop_IMDSv2_YOURID
severity: high
description: Identify collected EC2 instances that do not require IMDSv2 tokens.
remediation: Review application requirements before requiring IMDSv2 tokens.
```

6. Create it with `lacework policy create -f YOUR_POLICY_FILE` and the same sandpit flags.
7. Record the returned policy ID.

8. Find the policy in **Policy Manager > Policies**.
9. Confirm that it remains disabled.

Checkpoint: The saved policy references your query. Both enabled fields are false.



Step 5: Review a tuning change

Open your own policy. Change its description or severity using the available editor. Keep it disabled. Read the saved value back.

Checkpoint: Only your policy changed. Record the previous and new values.

Do not enable the policy during this exercise. Activation requires a separate scope and routing review. Remove both queries and the policy in Lab 16.

Next: Lab 10: Build a custom compliance framework.

Lab 10: Build a custom compliance framework

Environment: FORTINETAPACDEMO. **Access:** Read/write. **Time:** 30 minutes.

Objectives

Group policies for a specific reporting purpose. Keep a custom framework distinct from the original CIS benchmark.

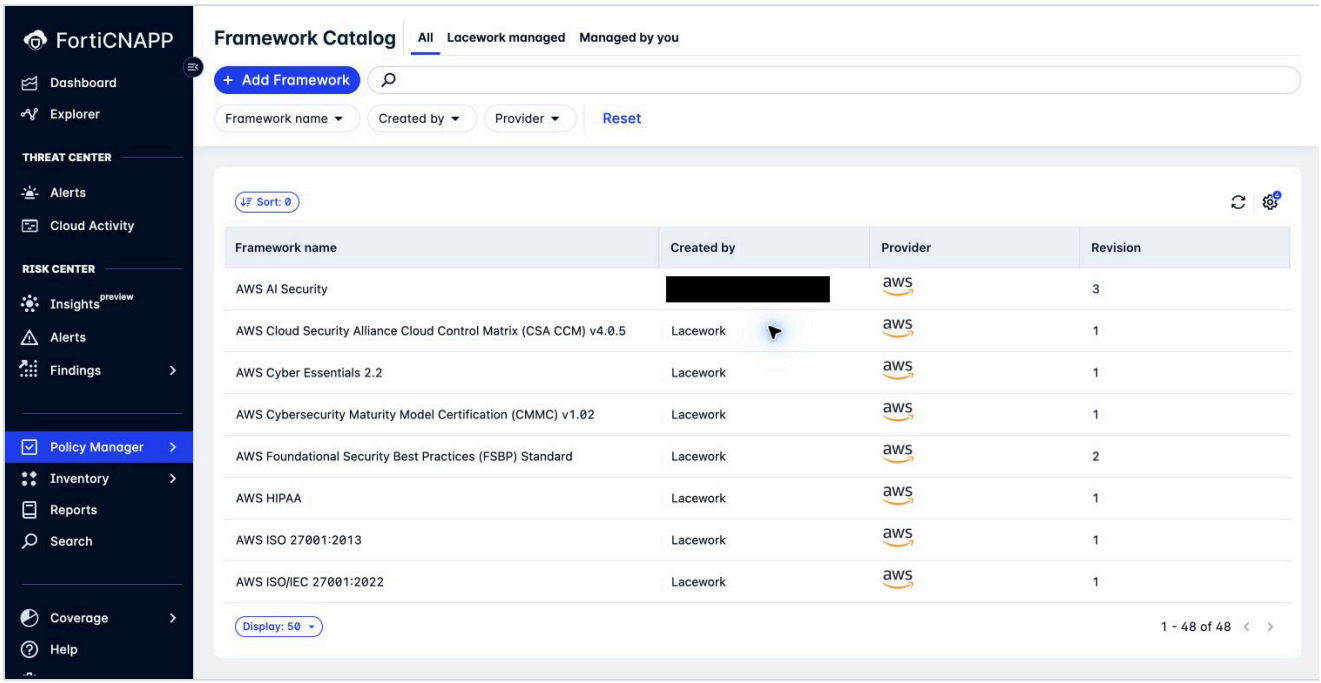
Prerequisites

Complete Lab 7. Use your participant ID. Use the AWS or Azure framework that the instructor selects. Screenshots show the demo tenant. Save only in the sandpit.

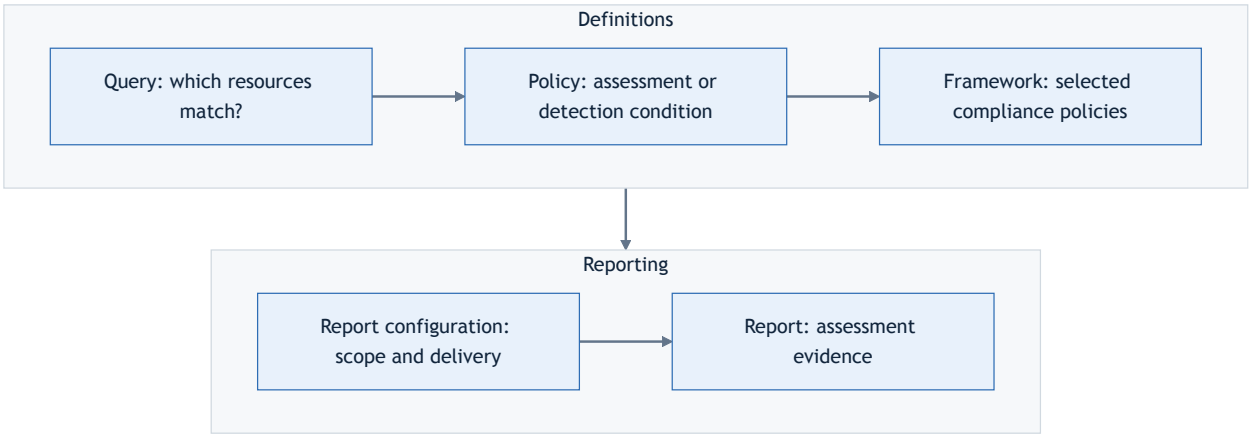
Lab steps

Step 1: Inspect the framework catalog

1. Confirm **FORTINETAPACDEMO**.
2. Open **Policy Manager > Frameworks**.
3. Compare **Lacework managed** with **Managed by you**.
4. Open a built-in framework.
5. Inspect its sections and policy mappings.



Checkpoint: Explain the difference between a policy and a framework.



This diagram shows the compliance reporting relationship. Other policy categories have different workflows.

Step 2: Create a custom framework

1. Return to the catalog.
2. Click **Add Framework**.
3. Select the instructor's source framework.
4. Continue to the framework editor.
5. Set a unique name: `Workshop-YOURID-AWS-review` or `Workshop-YOURID-Azure-review`.
6. Select **Networking** in the copied framework.
7. Click **Add / Edit policies**.
8. Select **Selected policies**.
9. Clear one selected policy.
10. Click **Update section**.
11. Save your custom framework.

Checkpoint: Your framework appears under **Managed by you**. The source framework is unchanged.

> **What matters:** A modified CIS-based framework is a custom control set. Do not present it as the complete, unchanged CIS benchmark.

Step 3: Review revision and evaluation state

1. Reopen your framework.
2. Record its revision and policy selection.
3. Check for **Pending changes**.
4. Explain which assessment results may still reflect the earlier configuration.

Checkpoint: Your worksheet records the framework name, provider, revision, and reporting purpose.

Framework changes can take up to 24 hours to appear in assessment results. Do not trigger repeated scans to force a classroom result. Keep this framework for cleanup. Lab 11 uses the built-in CIS frameworks for its main reports.

Next: Lab 11: Configure AWS and Azure CIS reports.

Lab 11: Configure AWS and Azure CIS reports

Environment: FORTINETAPACDEMO. **Access:** Read/write. **Time:** 40 minutes.

Objectives

Configure separate CIS reports for AWS and Azure. Select the correct framework version, data scope, assessment statuses, and delivery settings.

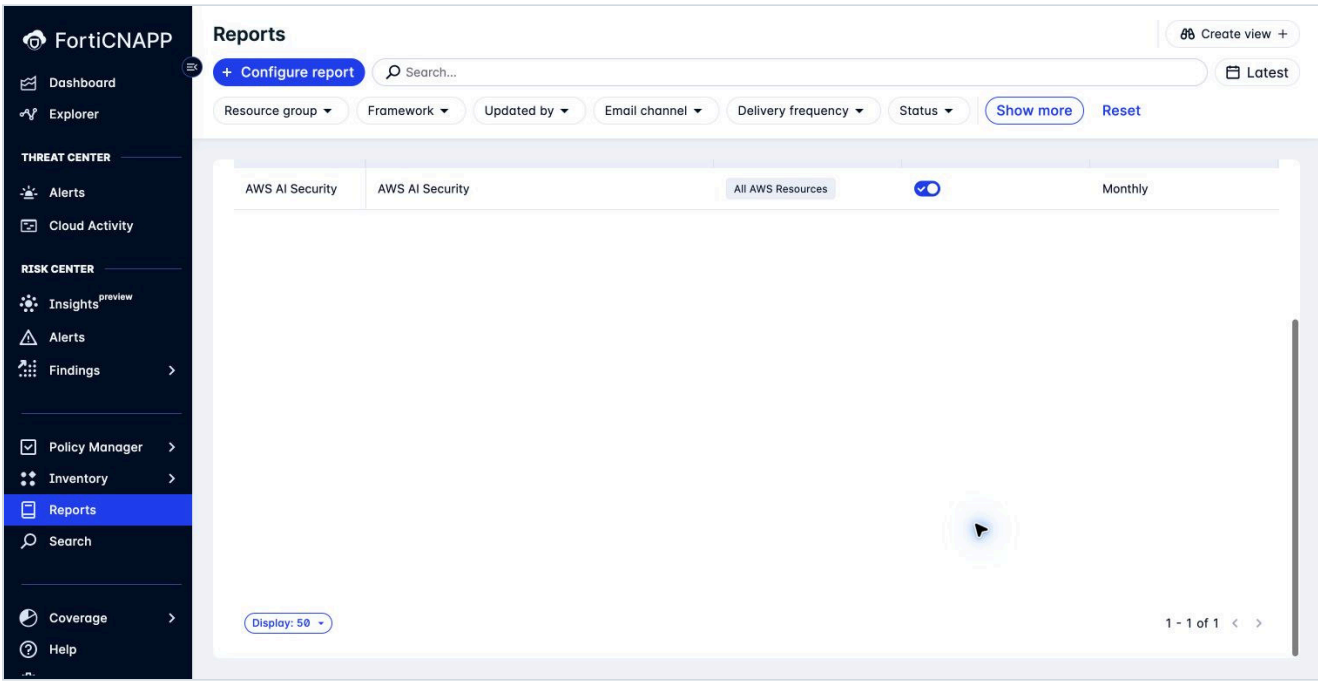
Prerequisites

Complete Labs 7 and 10. Ask the instructor for approved resource groups. Screenshots show demo report controls. Create reports only in the sandpit.

Lab steps

Step 1: Inspect existing configurations

1. Confirm **FORTINETAPACDEMO**.
2. Open **Reports**.
3. Inspect an AWS report configuration.
4. Inspect an Azure report configuration.
5. Record the framework and data scope for each.

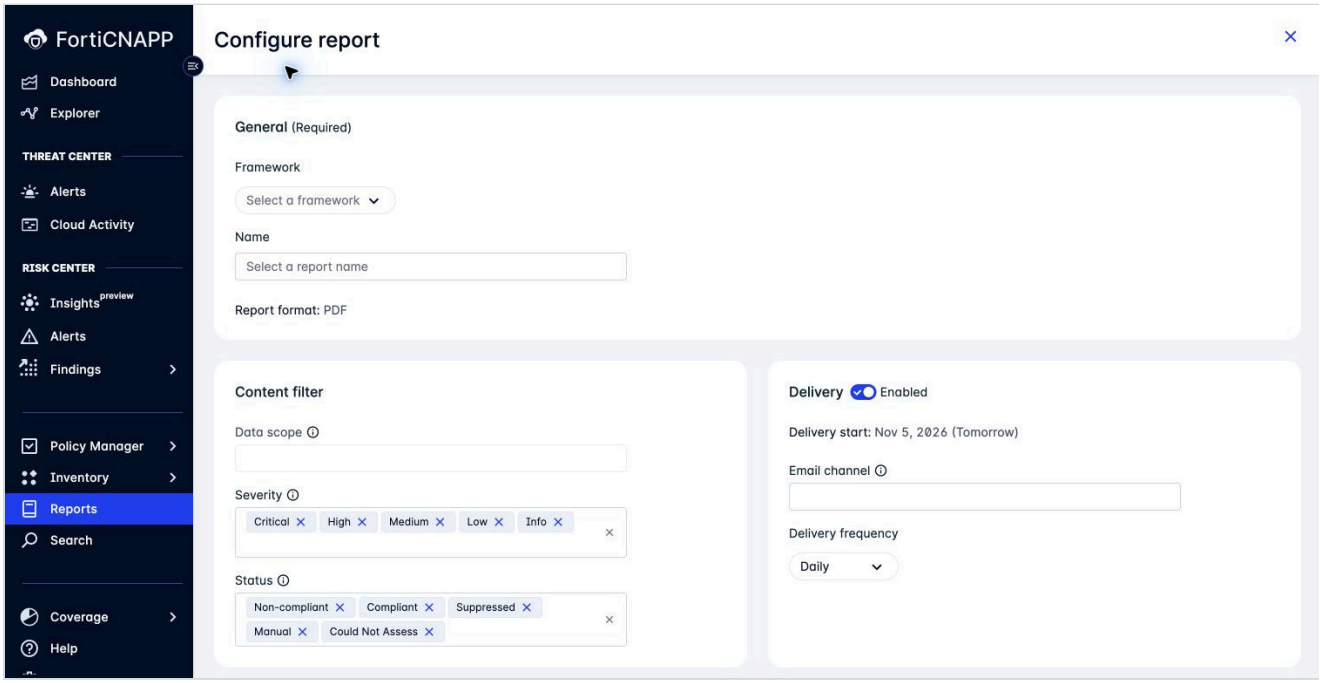


Checkpoint: Distinguish a report configuration from a generated assessment report.

Step 2: Configure the AWS report

1. Return to **Reports**.
2. Click **Configure report**.

3. Select the required AWS CIS framework and version.
4. Set **Name** to `Workshop-YOURID-AWS-CIS`.
5. Select the approved AWS **Data scope**.
6. Review **Severity**.
7. Review **Status**.
8. Turn off **Enabled** under **Delivery**.
9. Select the instructor-approved **Email channel**.
10. Review **Delivery frequency**.
11. Create the configuration.
12. Open the saved configuration.
13. Confirm that **Report configuration** is **Disabled**.
14. Turn off its switch if the saved configuration is enabled.



Checkpoint: The saved configuration has the required AWS framework and scope. Delivery is disabled.

An email channel is required even when delivery is off. Check the saved configuration's state. Do not rely only on the creation form's switch.

> **What matters:** Keep **Manual** and **Could Not Assess** visible when the report must show assessment gaps. Hiding these statuses can remove evidence that the report reader needs.

Step 3: Configure the Azure report

Repeat Step 2 with the required Azure CIS framework. Use `Workshop-YOURID-Azure-CIS` as the name. Select the approved Azure subscription scope. Keep delivery disabled.

Checkpoint: You have two separate configurations. Each uses the correct provider, version, and data scope.

Step 4: Review the delivery plan

1. Record the intended recipients and frequency in your worksheet.
2. Compare them with the selected email channel.
3. Identify the owner who approves enabling delivery.

4. Check the available report preview from **Cloud Compliance > Frameworks**.

Checkpoint: Explain what each recipient will receive and which resources the report covers.

Do not enable delivery to a shared email channel during the lab. Keep both configurations for cleanup in Lab 16.

Next: Lab 12: Check coverage and notification routing.

Lab 12: Check coverage and notification routing

Environment: FORTINETAPACDEMO. **Access:** Read-only review. **Time:** 20 minutes.

Objectives

Check the evidence pipeline before trusting a result. Distinguish a detection policy, an alert route, and a report delivery configuration.

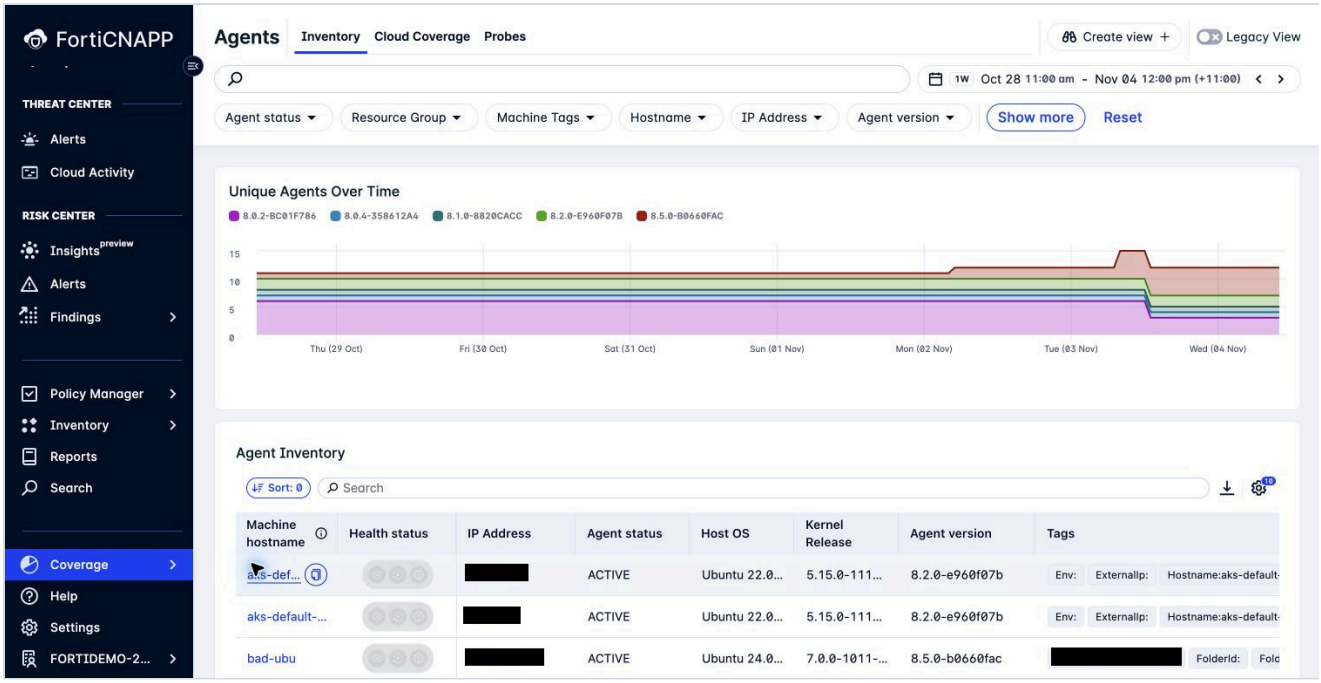
Prerequisites

Complete Lab 11. Do not change shared integrations or channels.

Lab steps

Step 1: Check collection

1. Open **Settings > Cloud accounts**.
2. Inspect the configuration integration for an AWS or Azure scope.
3. Check its state and last successful collection.
4. Inspect the activity log integration separately.
5. Open **Coverage > Agents**.
6. Check agent status and last check-in.
7. Open **Coverage > Agentless**.
8. Compare that coverage with the agent view.



This screenshot uses FORTIDEMO-2026-04. Check your own sandpit collection state during the exercise.

Checkpoint: Record one collection source and its latest successful update. An enabled integration and a healthy collection state are different checks.

Step 2: Review routing

1. Open **Settings > Channels**.
2. Inspect a channel without changing its recipients.
3. Examine the alert-routing controls available to your role.
4. Trace the intended route for a composite alert.
5. Compare that route with the email channel in your report configuration.

Checkpoint: Explain which setting defines the condition, which setting routes the alert, and which setting delivers the report.

> **What matters:** A correct detection is of limited operational value if its notification reaches no responsible team. A quiet inbox does not prove that the tenant has no important alerts.

Step 3: Record an operational issue

Write a short handover for one failed or stale collection, if present. Include the affected integration type, time, observed state, and next check. Keep credentials and unrelated identifiers out of the handover.

Checkpoint: Your handover reports the observed issue without claiming an unverified cause.

Next: Lab 13: Use the CLI with explicit tenant scope.

Lab 13: Use the CLI with explicit tenant scope

Environment: Both tenants. **Access:** Read-only. **Time:** 35 minutes.

Objectives

Retrieve the same evidence through the CLI. Use explicit scope and small JSON summaries. Keep credentials and unrelated tenant details out of shared output.

Prerequisites

Install `lacework` and `jq` using the CLI reference. Use an instructor-approved API key for your own access. Do not use a shared instructor admin key. Clone this repository or download its files. Run commands from the repository root.

Lab steps

Step 1: Check the tools

```
lacework version
jq --version
```

Checkpoint: Both commands print a version. The examples use bash or zsh. Use an approved equivalent shell for other systems.

Step 2: Configure separate profiles

Use the downloaded key file for each approved tenant. Replace the file paths below with your private paths.

```
lacework configure --profile fortidemo-2026-04-readonly-use \
  --account partner-demo --subaccount fortidemo-2026-04 \
  --json_file /PRIVATE/PATH/demo-key.json --noninteractive

lacework configure --profile fortinetapacdemo \
  --account partner-demo --subaccount fortinetapacdemo \
  --json_file /PRIVATE/PATH/sandpit-key.json --noninteractive
```

These commands save local credentials. They do not create an API key.

> **Caution**
>
> Keep key files and CLI configuration private. Do not paste them into chat, tickets, or Git. A profile named `readonly-use` does not reduce the key's actual permissions.

Step 3: Verify the selected scope

```
lacework configure show account --profile fortidemo-2026-04-readonly-use
lacework configure show subaccount --profile fortidemo-2026-04-readonly-use
```

Checkpoint: The account is `partner-demo`. The subaccount is `fortidemo-2026-04`. Do not print the complete CLI configuration.

Step 4: Find composite alerts

```
set -o pipefail
sh tools/lw-read.sh demo alert list --start -7d --end now \
  | jq '[.[] | select(.derivedFields.category == "Composite")]
    | group_by(.alertName)
    | map({name:.[0].alertName,count:length,
        severities:([.[].severity] | unique)})'
```

Checkpoint: Compare the titles and period with the console. If the selected alert is older, use the same historical period in both tools. Each alert-list request must use a window of seven days or less.

> **Hint:** A month in the console and seven days in the CLI are different datasets. Match time, category, severity, and status before comparing counts.

Step 5: Summarise integration coverage

```
sh tools/lw-read.sh sandpit cloud-account list \
  | jq 'group_by(.type)
    | map({type:.[0].type,total:length,
        enabled:([.[] | select(.enabled == 1)] | length),
        healthy:([.[] | select(.state.ok == true)] | length)})'
```

Checkpoint: Explain why an enabled integration can still need attention. The output exposes counts, not cloud account IDs or role ARNs.

The wrapper accepts selected read commands and fixes the tenant flags. Its restrictions do not replace restricted API credentials. For Lab 9, use native commands with explicit sandpit flags because that lab saves new objects.

Next: Lab 14: Retrieve evidence through the API.

Lab 14: Retrieve evidence through the API

Environment: Both tenants. **Access:** Read-only. **Time:** 40 minutes.

Objectives

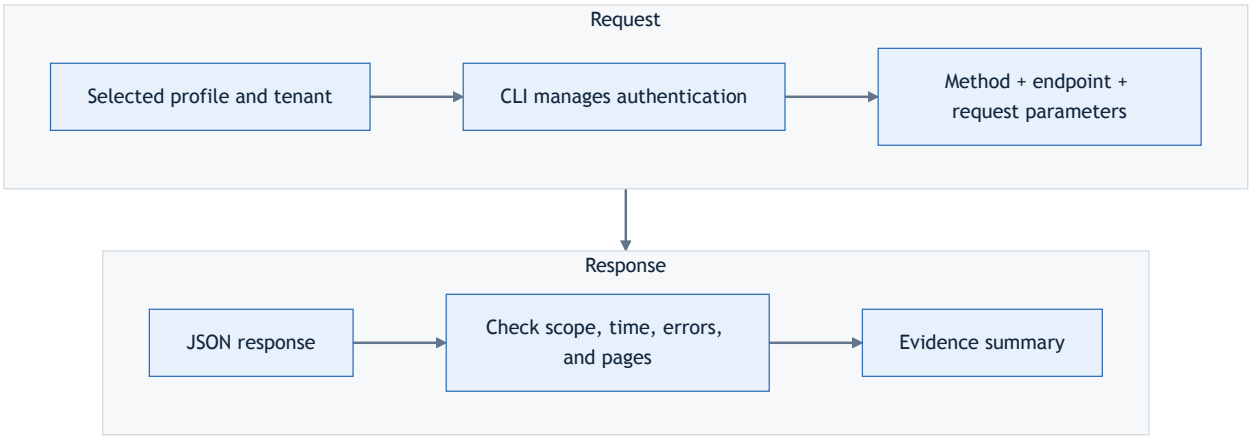
Understand a REST request and its response. Retrieve the alert behind a console investigation. Check time filters, response shape, and pagination before reporting counts.

Prerequisites

Complete Lab 13. Keep an alert ID from your composite investigation. Use the API endpoint documentation for request fields.

Lab steps

Step 1: Identify the request parts



The `lacework api` command calls the REST API. The CLI manages authentication for the selected profile. You still need to understand the endpoint and response contract.

Step 2: Compare a CLI list with an API response

```
set -o pipefail
sh tools/lw-read.sh sandpit api get /api/v2/CloudAccounts \
  | jq '{responseFields:keys,returnedRows:(.data | length)}'
```

Compare the shape with `cloud-account list` from Lab 13. The native list command returns an array. This REST response wraps rows in `data`.

Checkpoint: Explain why the same `jq` expression does not work for every command.

Step 3: Retrieve one alert

Set the ID from your own investigation:

```
ALERT_ID=REPLACE_WITH_ALERT_ID
sh tools/lw-read.sh demo api get \
  "/api/v2/Alerts/${ALERT_ID}?scope=Details" \
  | jq '{responseFields:keys,dataFields:(.data | keys)}'
```

Checkpoint: The request succeeds in the expected tenant. Inspect the required evidence in an approved private workspace. Share only the fields needed for your conclusion. Alert details can contain hostnames, addresses, identities, and command lines.

Step 4: Understand search requests

A documented search endpoint can use `POST` without changing tenant configuration. The method alone does not establish whether a request changes state. Check the endpoint's documented purpose before using it.

Run this read-only search in the sandpit:

```
REQUEST_FILE=$(mktemp)
jq -n '{timeFilter:{
  startTime:(now-86400 | floor | todate),
  endTime:(now | floor | todate)}}' > "$REQUEST_FILE"

lacework api post /api/v2/Alerts/search --file "$REQUEST_FILE" \
  --profile fortinetapacdemo --account partner-demo \
  --subaccount fortinetapacdemo --json --noninteractive \
  | jq 'if . == null then {returnedRows:0,hasMore:false}
    else {returnedRows:(.data | length),
      hasMore:(.paging.urls.nextPage != null)} end'

rm -f "$REQUEST_FILE"
```

Identify the `timeFilter` before execution. The request asks for the last 24 hours. Keep this exercise separate from create, update, scan, and delete operations.

Checkpoint: Explain why a search POST and a policy creation POST have different effects.

Step 5: Check completeness

1. Inspect the endpoint's response schema.
2. Check for paging metadata and a next-page link.
3. Retrieve all required pages before calculating a full total.
4. Record the time window and filters with the result.
5. Preserve request failures as failures.

Checkpoint: State whether your result is complete, a sample, or an incomplete check.

> **What matters:** An empty result, a failed request, and a first page are different outcomes. Do not turn any of them into an unsupported claim about tenant security.

Next: Lab 15: Investigate with the FortiCNAPP agent skill.

Lab 15: Investigate with the FortiCNAPP agent skill

Environment: Both tenants. **Access:** Read-only. **Time:** 35 minutes.

Objectives

Use the agent skill to repeat a known investigation. Validate its answer against the underlying evidence. Keep the external agent skill distinct from FortiCNAPP AI Assist and the workload agent.

Prerequisites

Complete Labs 2, 13, and 14. Use an approved AI coding agent. Confirm that your organisation permits the selected tenant data in that agent runtime. Keep the CLI profiles from Lab 13.

Lab steps

Step 1: Identify the three agents

Component	Purpose
FortiCNAPP workload agent	Collects workload telemetry
FortiCNAPP AI Assist	Provides assistance inside the console
FortiCNAPP agent skill	Supplies investigation instructions to an external coding agent using the CLI and API

Checkpoint: Explain which component collects process telemetry and which component runs CLI/API investigations.

Step 2: Install or inspect the skill

Use the skill repository for current runtime setup. For Codex, the repository documents this installation target:

```
git clone https://github.com/andrewbearsley/forticnapp-lacework-skill.git \
  ~/.agents/skills/forticnapp-lacework
```

If the skill is already installed, inspect its `SKILL.md` instead. Do not clone over an existing installation. Confirm that the selected runtime loads the skill before continuing.

Checkpoint: Identify the installed skill version and its read-only defaults.

Step 3: Repeat the composite investigation

Invoke `$forticnapp-lacework` in Codex. Supply this task with your chosen ID and period:

```
Use profile fortidemo-2026-04-readonly-use, account partner-demo,
and subaccount fortidemo-2026-04.
Use read operations only. Do not change any tenant state.
Investigate composite alert REPLACE_ID for REPLACE_PERIOD.
Confirm the tenant before requesting data.
Summarise observations, entities, and the activity sequence.
Separate observed facts from hypotheses.
```

```
State the evidence sources and any incomplete checks.
Reduce output before displaying it. Keep secrets and unrelated identifiers private.
```

Checkpoint: Compare the result with your Lab 2 worksheet. Check at least two claims against the console or API evidence.

Step 4: Check sandpit coverage

```
Use profile fortinetapacdemo, account partner-demo,
and subaccount fortinetapacdemo.
Use read operations only.
Check cloud integration status and workload agent coverage.
Report counts, stale collection, and failures.
Distinguish data collection health from security findings.
Do not change policies, alerts, integrations, or reports.
```

Checkpoint: A failed integration is reported as an issue. A request failure remains an incomplete check.

Step 5: Review the answer

Ask the agent which source supports its main conclusion. Compare the requested time period with the period it actually queried. Check whether it handled all required pages. Correct any unsupported statement in your worksheet.

Checkpoint: Explain what the skill saved you and what you still had to verify.

Next: Lab 16: Complete the investigation and remove lab objects.

Lab 16: Complete the investigation and remove lab objects

Environment: Demo for investigation; sandpit for cleanup. **Time:** 30 minutes.

Objectives

Present an evidence-based investigation. Confirm report scope and remove your workshop objects.

Prerequisites

Keep your evidence worksheet and the IDs of every object that you created.

Lab steps

Step 1: Present the investigation

1. Confirm **FORTIDEMO-2026-04**.
2. Present the composite alert and its activity window.
3. Explain two related observations.
4. State the affected entities and evidence sources.
5. Separate confirmed facts from hypotheses.
6. Propose a response and a verification method.

Checkpoint: Another participant can trace each main conclusion to its evidence. Do not change the demo alert's status or comments.

Step 2: Explain the risk and compliance evidence

1. Explain an exposure path and a possible interruption.
2. State why that path does not prove exploitation.
3. Identify the CIS framework provider and version.
4. Explain one failed control and one assessment gap.
5. Show the scope of each sandpit report configuration.

Checkpoint: Your explanation keeps incident evidence, exposure, and compliance assessment distinct.

Step 3: Remove your report configurations

1. Switch to **FORTINETAPACDEMO**.
2. Open **Reports**.
3. Find each configuration from your created-object record.
4. Confirm its exact name and framework.
5. Remove only your workshop configurations using the available action.
6. Verify that they no longer appear.

Checkpoint: No workshop report configuration remains for your participant ID.

Step 4: Remove your policies, framework, and queries

1. Open **Policy Manager > Policies**.
2. Remove your disabled workshop policy by its recorded ID.
3. Open **Policy Manager > Frameworks**.
4. Remove your custom workshop framework.
5. Open **Policy Manager > Queries**.
6. Remove your QBL and LQL workshop queries.
7. Verify that each recorded ID is absent.

Remove dependent objects first. Do not remove a query that an existing shared policy uses. Never select all objects for cleanup.

Checkpoint: Your created-object record shows the removal of every object you created.

Step 5: Close the session

Close private exports and credential files. Follow the instructor's credential retention instructions. Do not revoke a shared key or remove another participant's local profile.

Checkpoint: FORTIDEMO-2026-04 is unchanged. No new cloud resources were needed for the workshop.

Return to the workshop overview.

Investigation worksheet

Use one copy per participant. Keep live identifiers in your approved private storage.

Field	Your evidence
Participant ID	
Tenant	
Alert title and ID	
Time range and timezone	
Composite observations	
Primary entities	
Confirmed facts	
Hypotheses that need checking	
Proposed response	
Attack path entry point	
Target resource	
Proposed path interruption	
CIS provider and benchmark version	
Failed control and affected resource	
Manual or unassessed controls	
Report scope and delivery settings	
CLI/API source and pagination status	
Skill conclusion checked against evidence	

Created objects

Tenant	Object type	Name	ID	Removed
FORTINETAPACDEMO				

Completion

Explain the incident evidence to another participant. Explain the difference between an observed action and a possible attack path. Show the CIS framework version and report scope. Confirm that your workshop objects are removed.